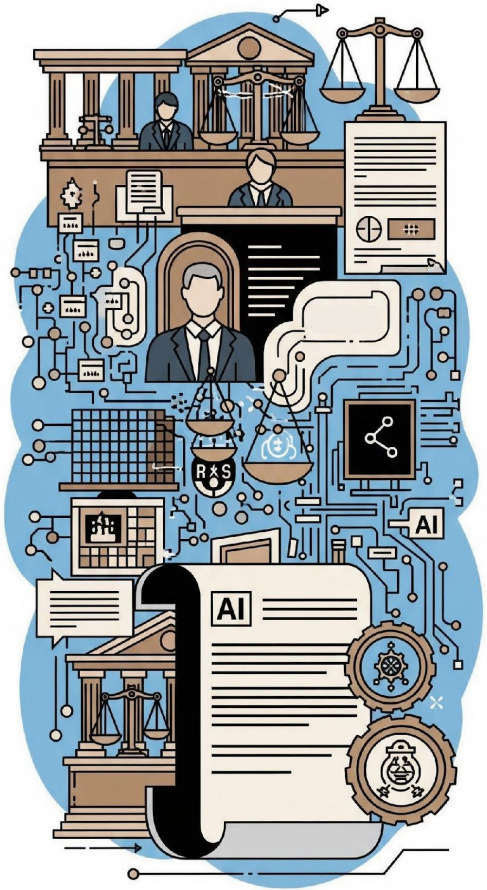
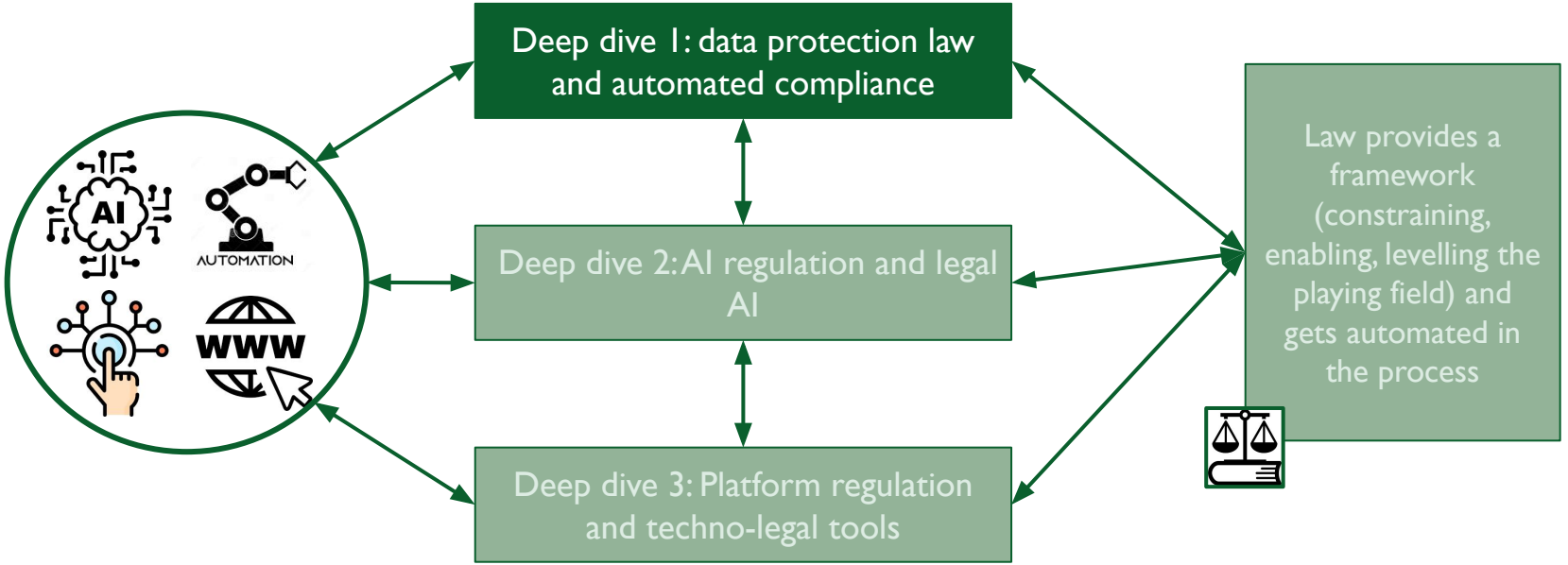
Universität St.Gallen

Deep Dive 1:
Data protection regulation and automated compliance



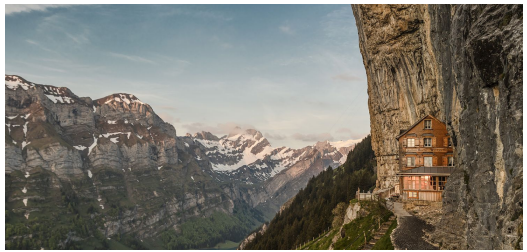
From insight to impact.

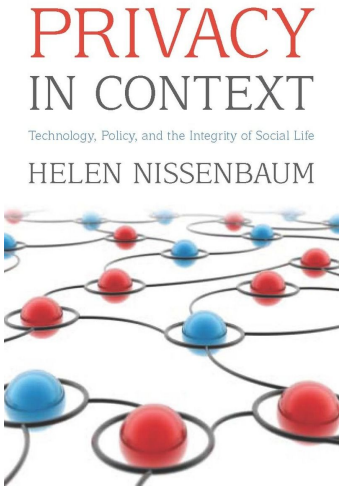
Deep dive I


AI
AUTOMATION
WWW
Deep dive 1: data protection law and automated compliance
Deep dive 2: AI regulation and legal AI
Deep dive 3: Platform regulation and techno-legal tools
Law provides a framework (constraining, enabling, levelling the playing field) and gets automated in the process

Privacy themes

Seclusion / Secrecy / Boundary Management





Contextual integrity / appropriate flow

Control / Self-determination



How do you think the theme of seclusion is challenged today?



Control

"… Privacy is the claim of individuals, groups, or institutions to determine for **themselves when, how, and to what extent information about them is communicated to others**. Viewed in terms of the relation of the individual to social participation, privacy is the voluntary and temporary withdrawal of a person from the general society through physical or psychological means, either in a state of solitude or small-group intimacy or, when among larger groups, in a condition of anonymity or reserve. The **individual's desire for privacy is never absolute**, since participation in society is an equally powerful desire. Thus, each individual is continually engaged in a personal adjustment process in which he **balances the desire for privacy with the desire for disclosure and communication of himself to others**, in light of the environmental condition and social norms set by the society in which he lives."

Westin, A. F. (1967). *Privacy and Freedom*, Atheneum.

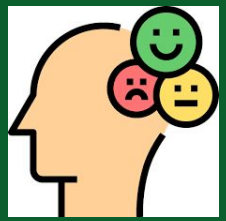
What do you think are the reasons why control is necessary?



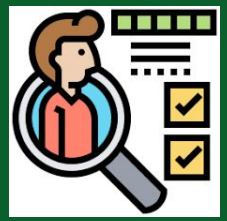
Emotional release

Self-evaluation













Time out from social restrictions

Build interpersonal relationships

Control

"If you're at work and you have a photograph of your child on your desk, and your co-worker says, 'Oh, my gosh, your kid's so cute. That's fantastic! Can I see your phone so I can see **all the pictures** of your child?' You go, '**No, this is the picture I'm comfortable sharing with you**'."



Facebook told advertisers it can identify teens feeling 'insecure' and 'worthless'

Leaked documents said to describe how the social network shares psychological insights on young people with advertisers

Sam Levin *in San Francisco*
@SamTLevin
Email
Mon 1 May 2017 20.01 BST
1494



Sample of

Google

climate change is

climate change is **a hoax**
climate change is **not real**
climate change is **real**
climate change **issues**

Press Enter to search.

This a
lose v

LIKELY BROWSING HISTORY

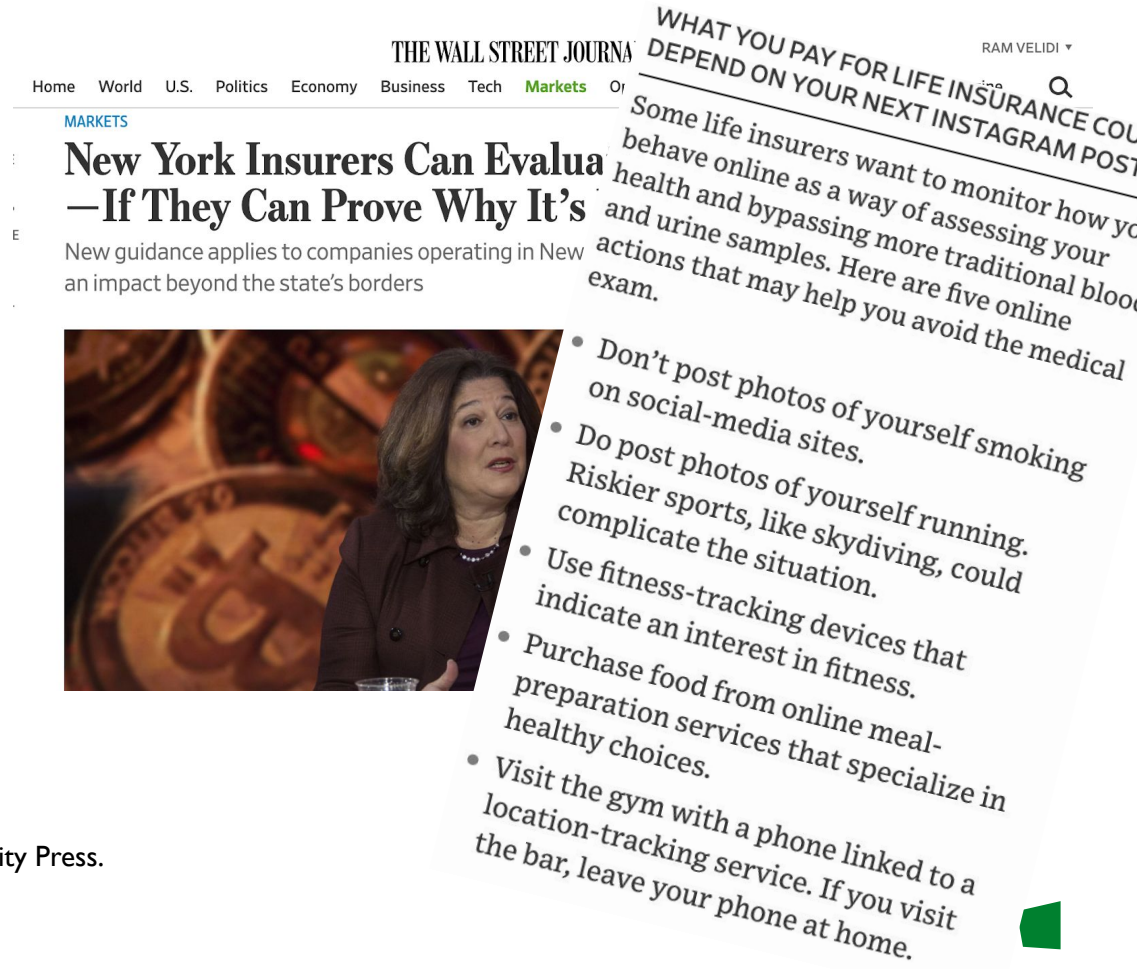
LIKELY CREDIT CARD HISTO

climate change

climate change - Google Search
climate change **definition**
climate change **organizations**
climate change **jobs**
climate change **art**
climate change **quizlet**

Contextuality

"The right to privacy is neither a right to secrecy, a right to control personal information, nor a right to have access to this information restricted, but a right **appropriate flow** of personal information."

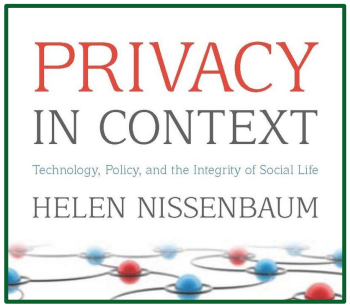


Nissenbaum, H. (2009). *Privacy in context.* Stanford University Press.

Principles of processing

Privacy themes







Seclusion I Secrecy I Boundary management

Contextual integrity I Appropriate flow

Control I Self-determination

Data protection principles

Data security

Purpose limitation

Fairness, Transparency

Consent, Individual rights

Data minimization

Storage limitation

Lawfulness, Accuracy

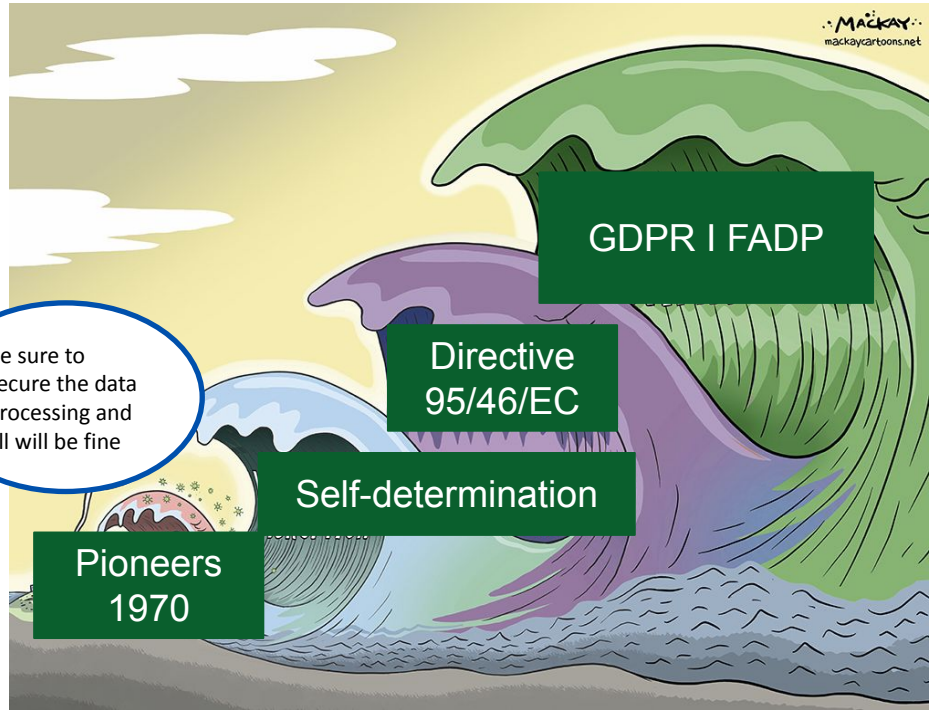
When was the first data protection law established?



Data protection law

Pioneers 1970
German State Hesse
Centralized data processing by the government after WWII
Technical database specifications

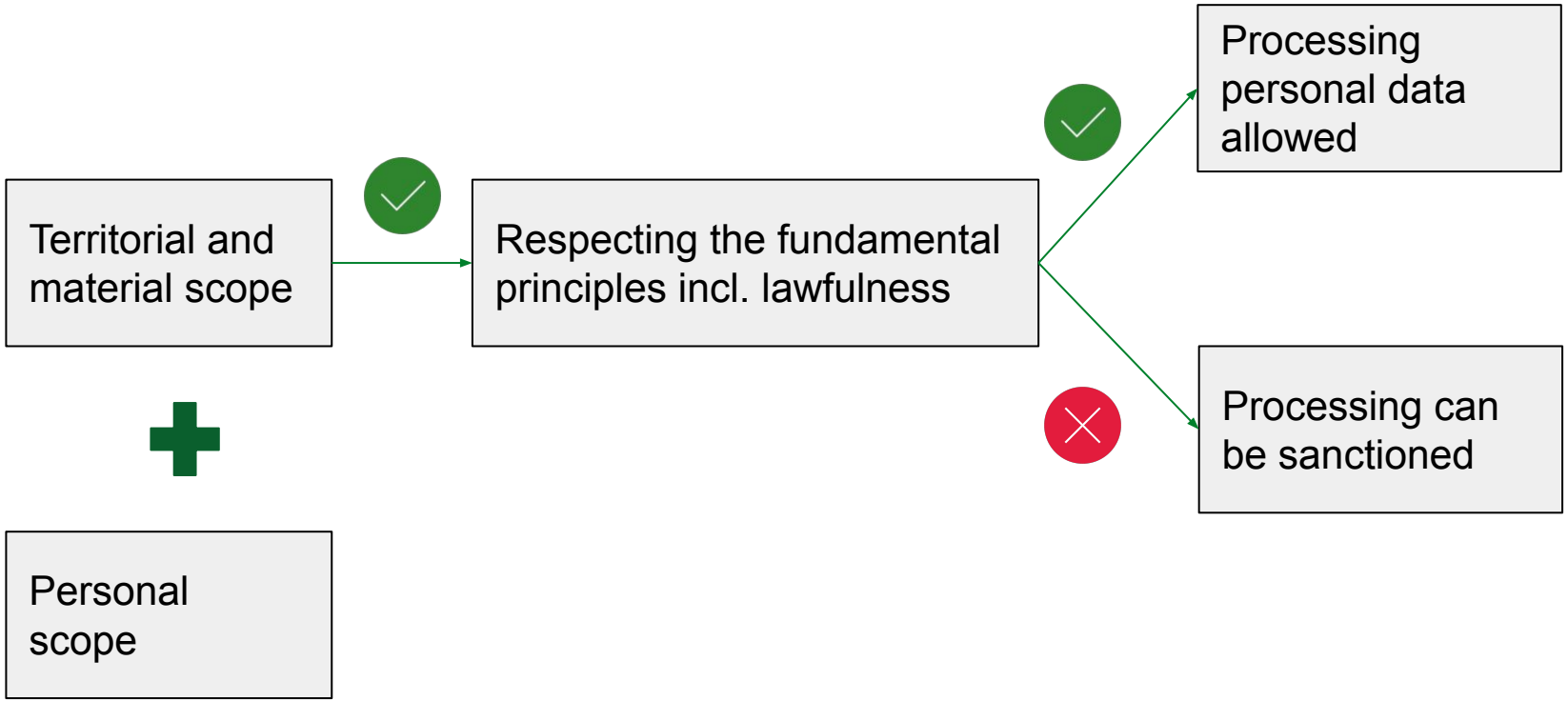
Self-determination
Census decision
Individual rights
More cross-border data flows
Focus on consent
Individual liberty and freedom
OECD guidelines and Convention 108



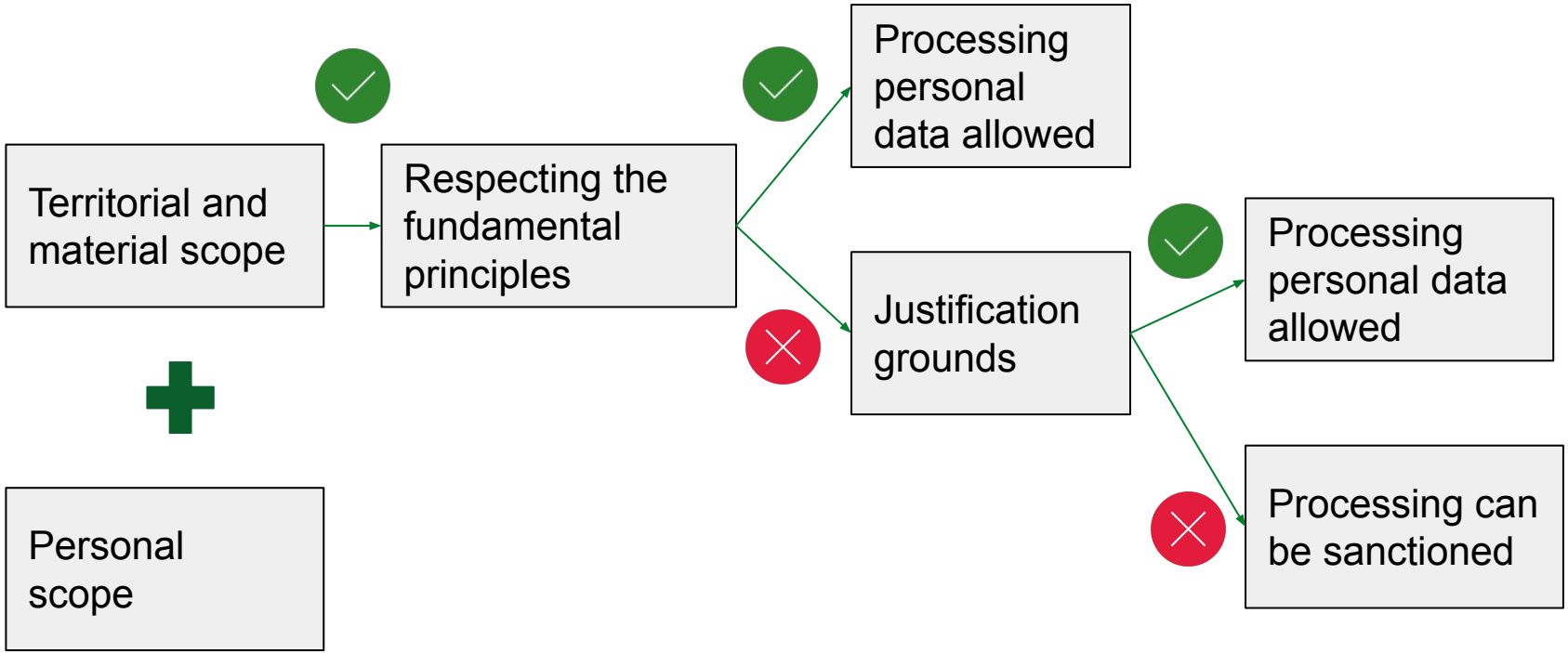
Harmonization within the EU
Increased data flows
Focus on consent leads to problems
Sensitive data and higher requirements

Further harmonization and increase in protection
Foster digital single market
Strengthen individual rights
Embedding technical protection (by design)

Taxonomy (GDPR)



Taxonomy (FADP)



What does processing personal data mean?



Material scope: *processing*



Art. 4(2) GDPR: 'processing' means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction

Material scope: *personal data*

'personal data' means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly…..

Non-personal data [0]

Personal data [1]

Non-personal data

Anonymized data



	Singling Out?	Linkability?	Inference?
Pseudonymisation	Yes	Yes	Yes
Noise addition	Yes	May not	May not
Substitution	Yes	Yes	May not
Aggregation or K-anonymity	No	Yes	Yes
L-diversity	No	May not	May not
Differential privacy	May not	May not	May not
Hashing/Tokenization	Yes	Yes	May not

Identifier

Combined data

Pseudonym

Sensitive data

Profiling

means reasonably likely to be used?

(26) The principles of data protection should apply to any information concerning an identified or identifiable natural person. Personal data which have undergone pseudonymisation, which could be attributed to a natural person by the use of additional information should be considered to be information on an identifiable natural person. To determine whether a natural person is identifiable, account should be taken of all the means reasonably likely to be used, such as singling out, either by the controller or by another person to identify the natural person directly or indirectly. To ascertain whether means are reasonably likely to be used to identify the natural person, account should be taken of all objective factors, such as the costs of and the amount of time required for identification, taking into consideration the available technology at the time of the processing and technological developments. The principles of data protection should therefore not apply to anonymous information, namely information which does not relate to an identified or identifiable natural person or to personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable. This Regulation does not therefore concern the processing of such anonymous information, including for statistical or research purposes.

“The law of everything”

The law of everything. Broad concept of personal data and future of EU data protection law

Nadezhda Purtova

Tilburg Institute for Law, Technology, and Society (TILT), Tilburg University, Tilburg, The Netherlands

ABSTRACT

Article 29 Working Party guidelines and the case law of the CJEU facilitate a plausible argument that in the near future everything will be or will contain personal data, leading to the application of data protection to everything: technology is rapidly moving towards perfect identifiability of information; datafication and advances in data analytics make everything information; and in increasingly ‘smart’ environments [illegible] to relate to a person in purpose or effect. [illegible] personal data is not problematic [illegible] future. When the hyperconnected [illegible] the intensive compliance regulation (GDPR) will become ‘the law but impossible to maintain. By then we should abandon the distinction between personal and non-personal data, embrace the principle that all data processing may trigger protection, and understand how this protection can be scalable.

Broad scope of personal data: What can really be anonymous?

NETFLIX

Movie ratings

Breyer (EU)

Logistep (CH)

In view of the cases mentioned above, and along the same lines, it could be pointed out that, in order to consider that the data “relate” to an individual, a "**content**" element OR a "**purpose**" element OR a "**result**" element should be present.

Article 29 Data Protection Working Party, WP136, Opinion 4/2007 on the concept of personal data

Purpose: “Data are used… with the purpose to evaluate, treat, in a certain way or influence the status of behavior of an individual.”

Result: “Data likely has an impact on a person’s rights and interests.”



Territorial scope – where does the law apply?

The Brussel Effect

ECJ C-131/12
Inextricable link between the activity of Google Inc. (US; indexing of pages) and Google Spain (sale of local advertisement space) → Google Spain an establishment of Google Inc. in EU

Article 3

Territorial scope

1. This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.

2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to:

(a) the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or

(b) th monitoring of their behaviour as far as their behaviour takes place within the Union.

3. Th lation applies to the processing f personal data by a controller not established in the Union, but in a place where Member applies by virtue of public internatio law.

Recital 23 GDPR
"the use of a language or a currency generally used in one or more Member States with the possibility of ordering goods and services in that other language"

Recital 24 GDPR
Tracking on the internet
Use of personal data for profiling activities

Data (trails)



Is data the new oil? (quote from Clive Humby, 2006)

Similarities: Strategic value of both I in itself no real value is limited but it must be refined I both can be exchanged for money

But: oil decreases over time, not availability and extraction of data!

But: oil needs a lot of effort to be extracted and transported and once it is used, it is gone!

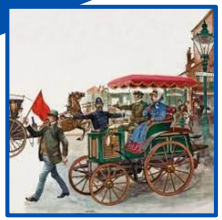
But: data is reusable, repurposable → data continues to have potential value and is more versatile in its use!



The Observatory of Anonymity, https://www.ooa.world

Metaphors matter as they shape regulatory discourse





What are core data protection principles?

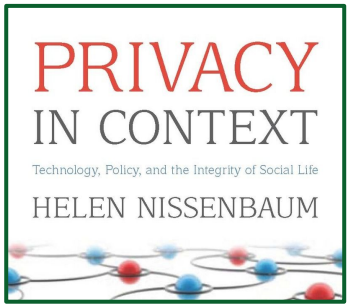


Principles of processing

Privacy themes



Seclusion I Secrecy I Boundary management



Contextual integrity I Appropriate flow



Control I Self-determination

Data protection principles

Data security

Purpose limitation

Fairness, Transparency

Consent, Individual rights

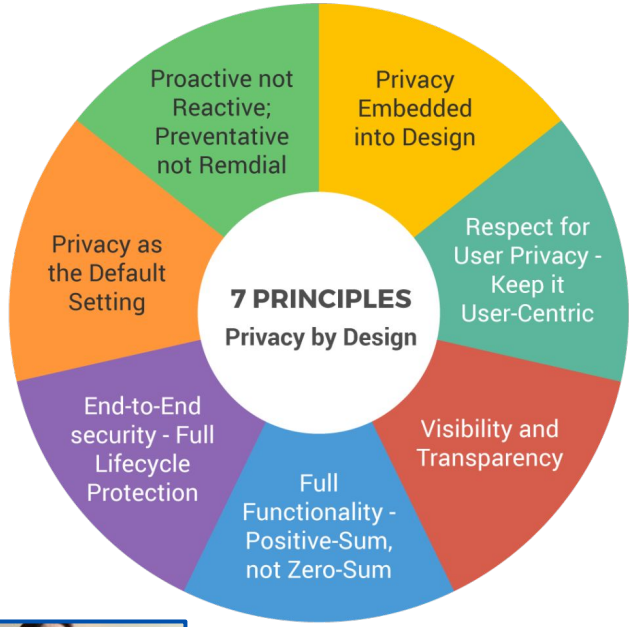
Data minimization

Storage limitation

Lawfulness, Accuracy

Key obligations of data controllers

- Documentation
- Information requirements
- Notification of data breaches
- Data protection impact assessments
- **Data protection by design and default**
- Specific provisions with respect to transfer of the data
- Compliance with individual rights requests





Trilogy of PbD: software, hardware, business practices

- European Commission (COM(2007) 228 final)
  - Objective: Promote and support development of PETs
- 32nd International Conference of Data Protection and Privacy Commissioners (2010)
  - Recognizes PbD as an essential component of privacy protection and promote its adoption
- European Data Protection Supervisor (2010)
  - Opinion on "Promoting trust in the information society"
- FTC Protecting Consumer Privacy in an Era of Rapid Change (2012)
  - "Companies should promote consumer privacy throughout their organizations and at every stage of the development of their products and services"
- OECD Privacy Guidelines (2013)
  - Acknowledges privacy by design as a new concept that should be implemented I Mandates the adoption and promotion of technical as well as educational measures

Design approach in data protection law

Article 25

Data protection by design and by default

1. Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, the controller shall, both at the time of the determination of the means for processing and at the time of the processing itself, implement appropriate technical and organisational measures, such as pseudonymisation, which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects.

2. The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed. That obligation applies to the amount of personal data collected, the extent of their processing, the period of their storage and their accessibility. In particular, such measures shall ensure that by default personal data are not made accessible without the individual's intervention to an indefinite number of natural persons.

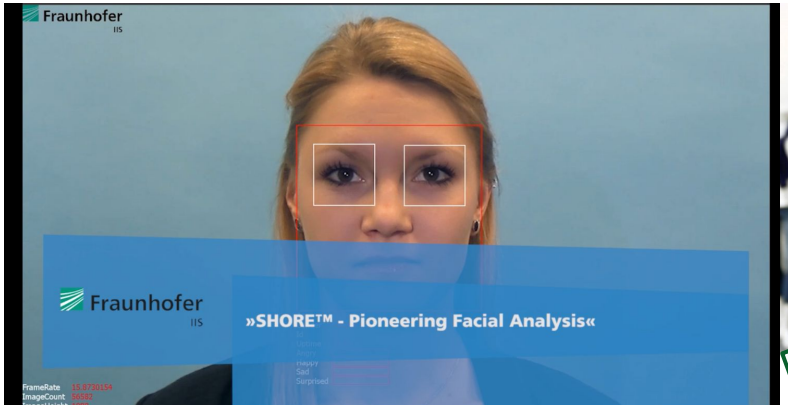
Art. 7 Data protection by design and data protection by default

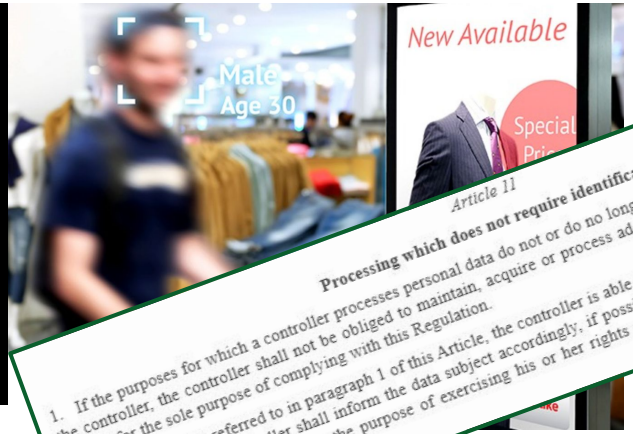
[1] The controller is obliged to arrange the data processing in technical and organisational terms so that the data protection regulations, and in particular the principles under Article 6, are respected. It shall take account of this from the planning stage.

[2] The technical and organisational measures must in particular be appropriate with regard to the state of the art, the nature and the extent of the data processing and the risk that the processing poses to the data subject's personality or fundamental rights.

[3] The controller is obliged to ensure by means of suitable default settings that the processing of personal data is limited to the minimum required for the purpose intended, unless the data subject specifies otherwise.

Transient processing and the material scope

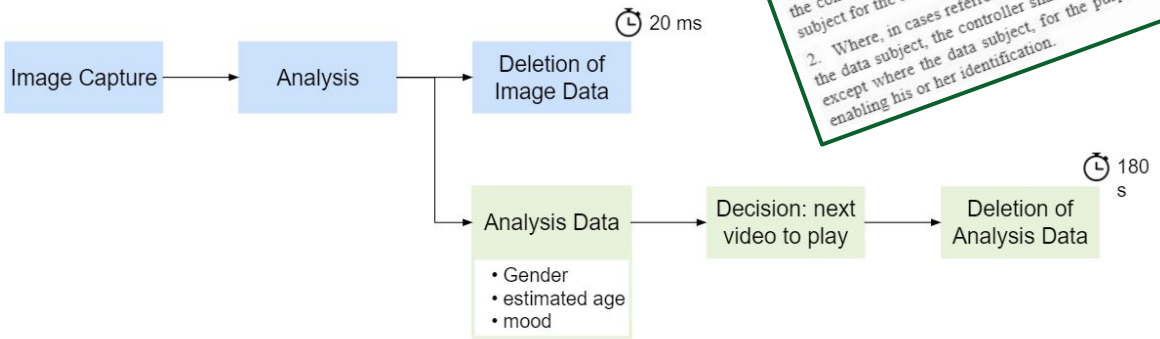




Article 11

Processing which does not require identification

1. If the purposes for which a controller processes personal data do not or do no longer require the identification of a data subject by the controller, the controller shall not be obliged to maintain, acquire or process additional information in order to identify the data subject for the sole purpose of complying with this Regulation.
2. Where, in cases referred to in paragraph 1 of this Article, the controller is able to demonstrate that it is not in a position to identify the data subject, the controller shall inform the data subject accordingly, if possible. In such cases, Articles 15 to 20 shall not apply except where the data subject, for the purpose of exercising his or her rights under those articles, provides additional information enabling his or her identification.



Galič, M., & Gellert, R. (2021). Data protection law beyond identifiability? Atmospheric profiles, nudging and the Stratumseind Living Lab. Computer Law & Security Review, 40, 105486.
George, D., Reutimann, K., & Tamò-Larrieux, A. (2019). GDPR bypass by design? Transient processing of data under the GDPR. *International Data Privacy Law, 9*(4), 285-298.

Visual Privacy: The Impact of Privacy Labels on Privacy Behaviors Online

Kimberly Garcia*
kimberly.garcia@unisg.ch
University of St.Gallen
St. Gallen, Switzerland

Aurelia Tamò Larrieux*
aurelia.tamo-larrieux@unil.ch
University of Lausanne
Lausanne, Switzerland

Yannic Meier
yannic.meier@uni-due.de
University of Duisburg-Essen
Duisburg, Germany

Simon Mayer
simon.mayer@unisg.ch
University of St.Gallen
St. Gallen, Switzerland

Christoph Lutz
christoph.lutz@bi.no
BI Norwegian Business School
Oslo, Norway

Clement Guitton
clement.guitton@unisg.ch
University of St.Gallen
St. Gallen, Switzerland

Leonardo Stern
ls@leonardostern.ch
University of St.Gallen
St. Gallen, Switzerland

Raffael Rot
raffael.rot@unisg.ch
University of St.Gallen
St. Gallen, Switzerland

Simeon Pilz
simeon.pilz@unisg.ch
University of St.Gallen
St. Gallen, Switzerland

Stephan Mulders
s.mulders@vandiepen.com
Maastricht University
Maastricht, Netherlands

Abstract

Research has consistently shown that websites' privacy policies fail to inform users, prompting to explore more condensed, visual solutions such as icons and privacy labels. However, we miss efficient and scalable systems to generate such privacy labels and conclusive evidence on their impact on people's privacy protection behavior. This paper fills these gaps: we present the *Visual Privacy* browser extension that automatically computes a privacy rating and visualizes it in a privacy label. We studied the impact of those labels on privacy protection behavior in an online experiment ($N = 825$). Our results show that the privacy labels shown by *Visual Privacy* significantly impact a website's perceived risks and benefits, and that they have an indirect effect on privacy protection behavior. Study participants showed high awareness and acceptance of privacy labels, with 79% of participants recalling the rating shown in a label and over 75% reporting that they would like them to become mandatory. While tested in a web context, this work lays the foundation for ubiquitous privacy transparency. *Visual Privacy* can be extended to mixed reality and smart environments, to inform users about the data practices of the connected devices they encounter in everyday life.

Keywords

Privacy Labels, Privacy Policies, Digital Privacy, Protection Motivation Theory, Data Protection, Privacy-by-Design.

*Both authors contributed equally to this research.

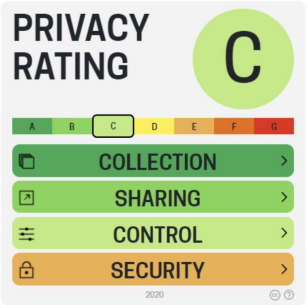
This work is licensed under the Creative Commons Attribution 4.0 International License. To view a copy of this license visit https://creativecommons.org/licenses/by/4.0/ or send a letter to Creative Commons, PO Box 1866, Mountain View, CA 94042, USA.

Pre-print YYYY(X), 1–16

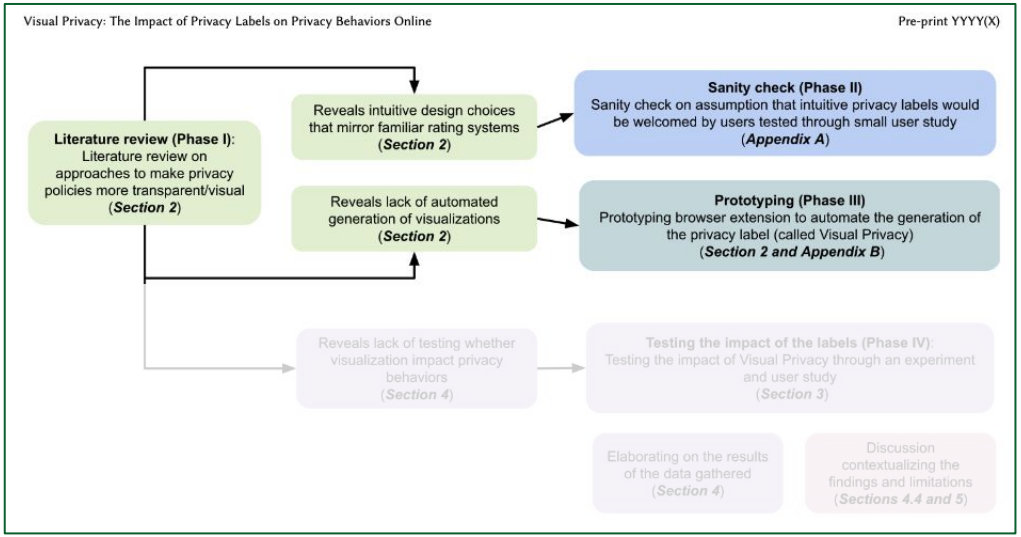
© YYYY Copyright held by the owner/author(s).

https://doi.org/XXXXXXX.XXXXXXX

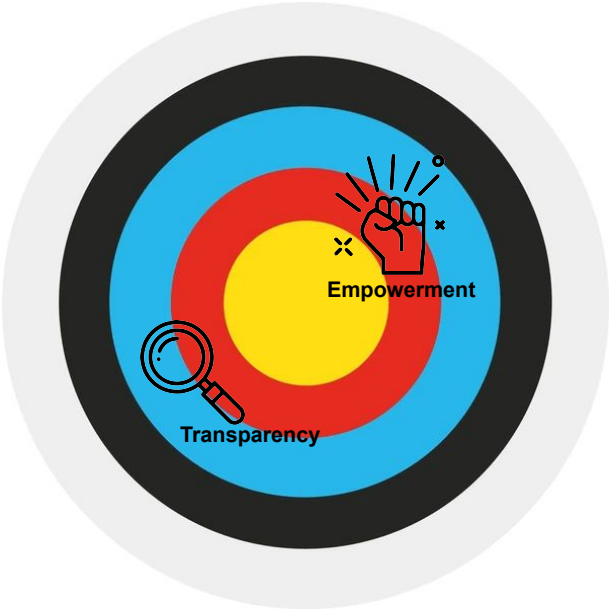
1 Introduction

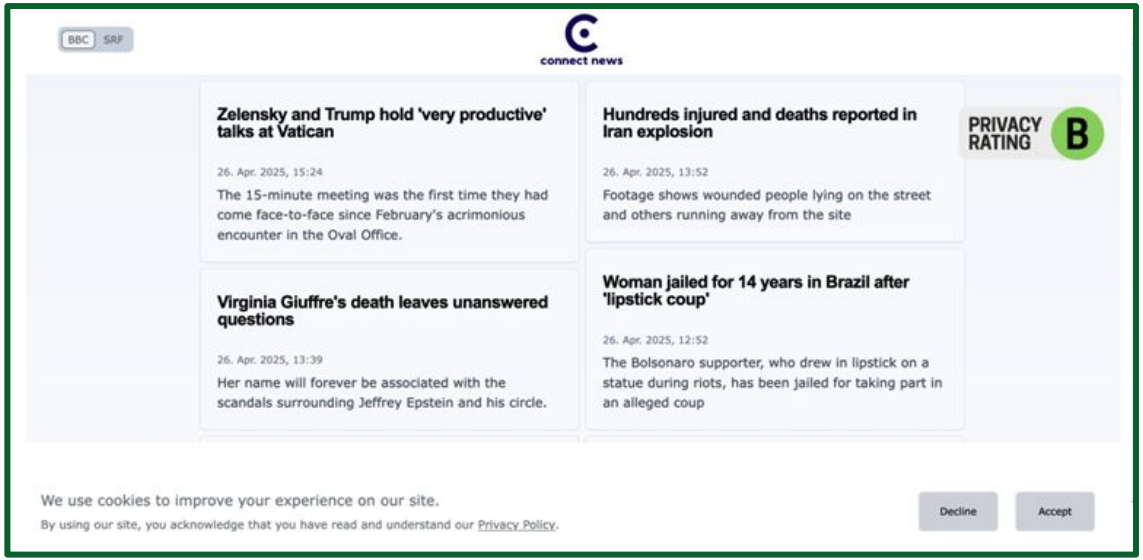


Models (LLMs) can be leveraged to automatically generate visualizations [20] or privacy labels [60]. These approaches have yet to

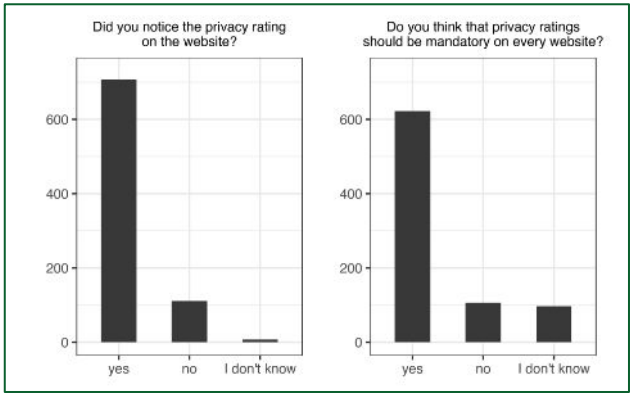


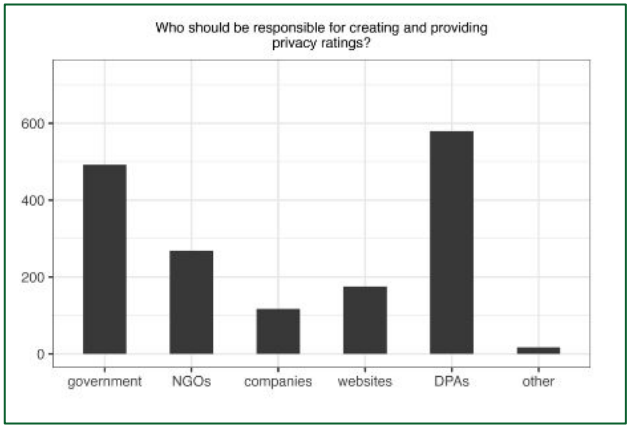
Regulatory goals within data protection:
ensuring transparency over data processing and enabling individuals to exercise their individual rights





Some of the findings





Trust
A bad rating *significantly* reduces trust placed in the website to handle their data responsibly

("I trust the website to handle my personal information correctly")

Perceived benefits
A bad rating negatively affects the benefits associated with the website *significantly*

("I find the website helpful for my daily life")

Perception of privacy threats
A bad rating *significantly* increases the perception of a privacy risk

("It is problematic when/likely that this website collects my personal information")

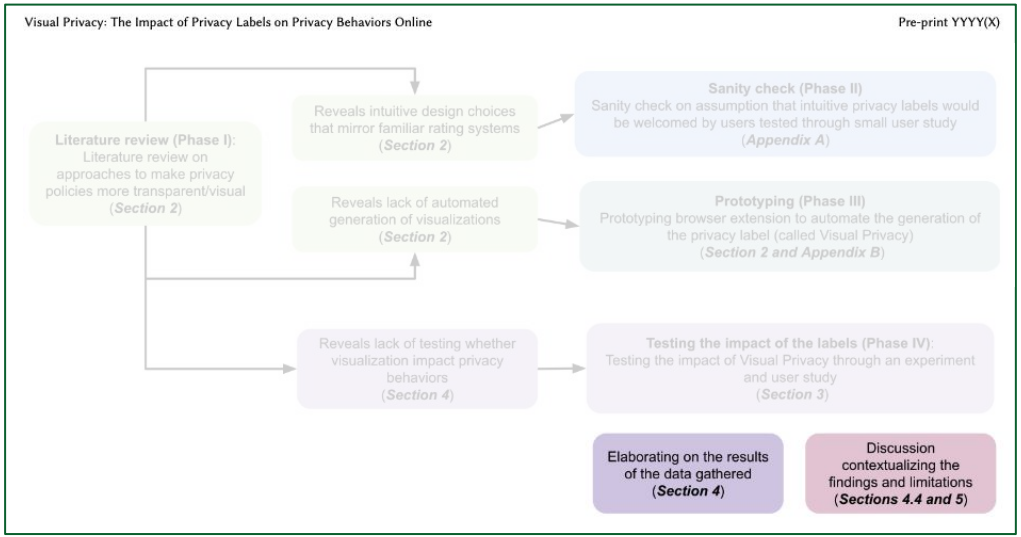
Threat appraisal

Privacy Research Day 2025: watch the replay

17 July 2025

The 4th edition of the CNIL's Privacy Research Day was held on July 1st 2025, at the CNIL in Paris and online. This event bridges the gap between the academic world and data regulation, and is aimed at practitioners, academics, and public authorities.





What are core data subject rights?



Core individual rights

Access Know what data is processed.	**Correction** Correct inaccurate data.	**Erasure** Delete data.	**Restriction** Temporarily limit use.
Contact Contact a supervisory authority.	**Human Review** Right not to be subject to automated decisions.	**Objection** Stop certain processing.	**Portability** Take data to another provider.



Max Schrems vs. Facebook: https://en.wikipedia.org/wiki/Max_Schrems

Data access and portability (EU)

General Data Protection Regulation (GDPR)

Article 15

Right of access by the data subject

1. The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data and the following information:

(a) the purposes of the processing;

(b) the categories of personal data concerned;

onal data have been or will be disclosed, in particular recipients in

sonal data will be stored, or, if not possible, the criteria used to

tification or erasure of personal data or restriction of processing of
h processing;

ject, any available information as to their source;

filing, referred to in Article 22(1) and (4) and, at least in those cases,
ell as the significance and the envisaged consequences of such

an international organisation, the data subject shall have the right to
relating to the transfer.

ndergoing processing. For any further copies requested by the data
administrative costs. Where the data subject makes the request by
subject, the information shall be provided in a commonly used electronic form.

4. The right to obtain a copy referred to in paragraph 3 shall not adversely affect the rights and freedoms of others.

Article 20

Right to data portability

1. The data subject shall have the right to receive the personal data concerning him or her, which he or she has provided to a controller, in a structured, commonly used and machine-readable format and have the right to transmit those data to another controller without hindrance from the controller to which the personal data have been provided, where:

(a) the processing is based on consent pursuant to point (a) of Article 6(1) or point (a) of Article 9(2) or on a contract pursuant to point (b) of Article 6(1); and

(b) the processing is carried out by automated means.

2. In exercising his or her right to data portability pursuant to paragraph 1, the data subject shall have the right to have the personal data transmitted directly from one controller to another, where technically feasible.

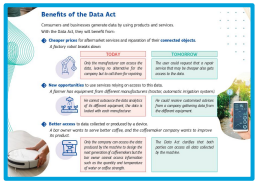
3. The exercise of the right referred to in paragraph 1 of this Article shall be without prejudice to Article 17. That right shall not apply to processing necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller.

4. The right referred to in paragraph 1 shall not adversely affect the rights and freedoms of others.

EU Data Act (DA)

Regulation 2023/2854

Applicable: 12 September 2025



Goal: Foster a competitive data market → data driven innovation!

Means: Access for individuals and business to data under certain conditions

PRESS RELEASE | Publication 11 January 2024

European Data Act enters into force, putting in place new rules for a fair and innovative data economy

The new rules define the rights to access and use data generated in the EU across all economic sectors and will make it easier to share data, in particular industrial data.



The Data Act will ensure fairness in the digital environment by clarifying who can
data and under which conditions. It will also stimulate a competitive and innovativ
unlocking industrial data, and by providing legal clarity as regards the use of data

Scope: Users of connected devices (individuals or businesses) control over the data they generate

Article 2

Definitions

For the purposes of this Regulation, the following definitions apply:

(1) 'data' means any digital representation of acts, facts or information and any compilation of such acts, facts or information, including in the form of sound, visual or audio-visual recording;

(2) 'metadata' means a structured description of the contents or the use of data facilitating the discovery or use of that data;

(3) 'personal data' means personal data as defined in Article 4, point (1), of Regulation (EU) 2016/679;

(4) 'non-personal data' means data other than personal data;

(5) 'connected product' means an item that obtains, generates or collects data concerning its use or environment and that is able to communicate product data via an electronic communications service, physical connection or on-device access, and whose primary function is not the storing, processing or transmission of data on behalf of any party other than the user;

(6) 'related service' means a digital service, other than an electronic communications service, including software, which is connected with the product at the time of the purchase, rent or lease in such a way that its absence would prevent the connected product from performing one or more of its functions, or which is subsequently connected to the product by the manufacturer or a third party to add to, update or adapt the functions of the connected product;

B2C and B2B data sharing (Chapter II)

Data access by design & default

Article 3

Obligation to make product data and related service data accessible to the user

1. Connected products shall be designed and manufactured, and related services shall be designed and provided, in such a manner that product data and related service data, including the relevant metadata necessary to interpret and use those data, are, by default, easily, securely, free of charge, in a comprehensive, structured, commonly used and machine-readable format, and, where relevant and technically feasible, directly accessible to the user.

Transparency obligations prior to the purchase, rent, or lease of a connected product and related services (Art. 3)

Transparency obligations

Chapter II, Art. 3

2. Before concluding a contract for the purchase, rent or lease of a connected product, the seller, rentor or lessor, which may be the manufacturer, shall provide at least the following information to the user, in a clear and comprehensible manner:

(a) the type, format and estimated volume of product data which the connected product is capable of generating;

(b) whether the connected product is capable of generating data continuously and in real-time;

(c) whether the connected product is capable of storing data on-device or on a remote server, including, where applicable, the intended duration of retention;

(d) how the user may access, retrieve or, where relevant, erase the data, including the technical means to do so, as well as their terms of use and quality of service.

3. Before concluding a contract for the provision of a related service, the provider of such related service shall provide at least the following information to the user, in a clear and comprehensible manner:

(a) the nature, estimated volume and collection frequency of product data that the prospective data holder is expected to obtain and, where relevant, the arrangements for the user to access or retrieve such data, including the prospective data holder's data storage arrangements and the duration of retention;

(b) the nature and estimated volume of related service data to be generated, as well as the arrangements for the user to access or retrieve such data, including the prospective data holder's data storage arrangements and the duration of retention;

(c) whether the prospective data holder expects to use readily available data itself and the purposes for which those data are to be used, and whether it intends to allow one or more third parties to use the data for purposes agreed upon with the user;

(d) the identity of the prospective data holder, such as its trading name and the geographical address at which it is established and, where applicable, of other data processing parties;

(e) the means of communication which make it possible to contact the prospective data holder quickly and communicate with that data holder efficiently;

(f) how the user can request that the data are shared with a third party and, where applicable, end the data sharing;

Limits to data access: Brillen Rottler under the GDPR…



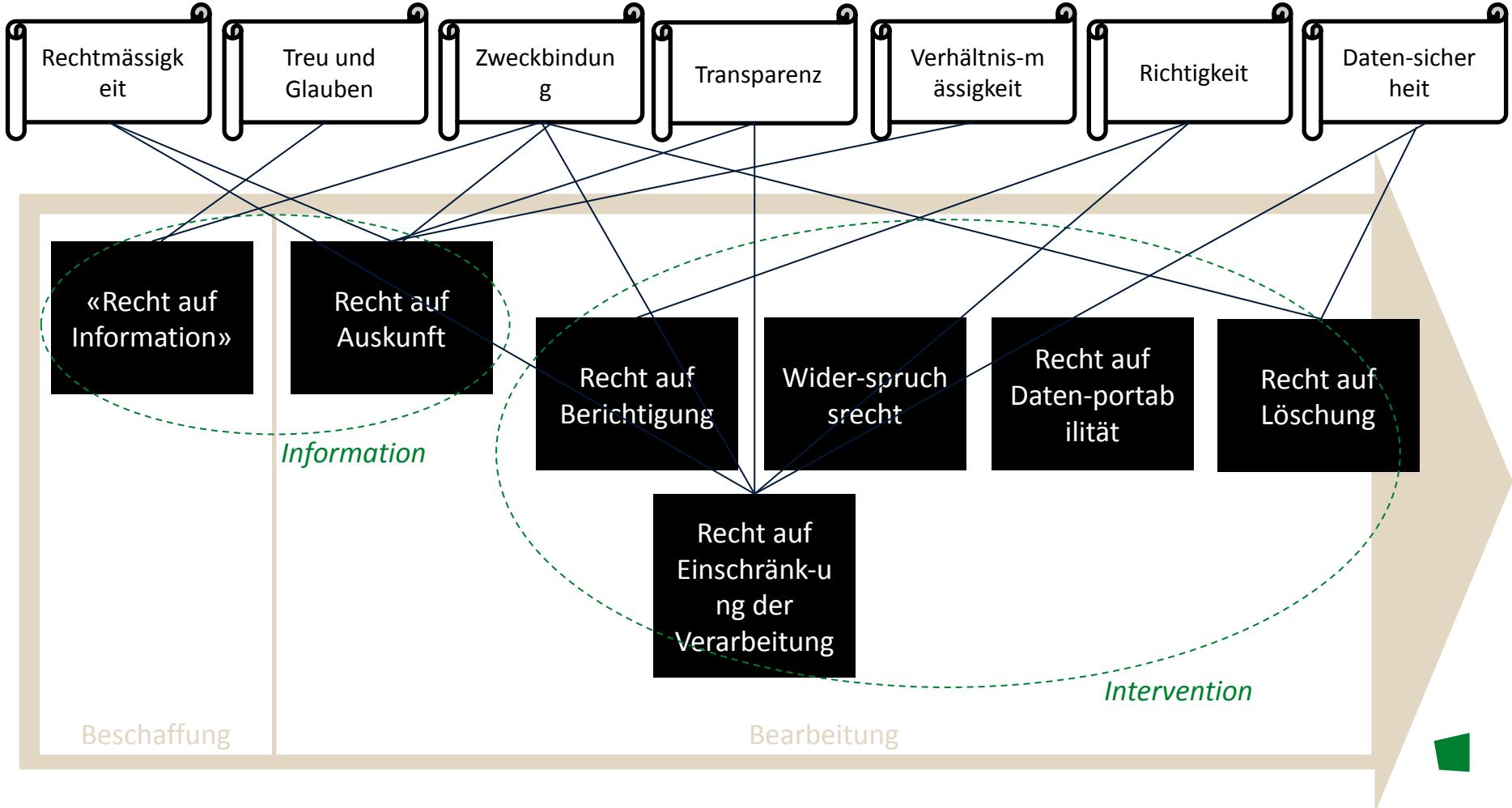
Facts: An individual signed up for a company's newsletter and immediately submitted an Article 15 GDPR access request. The company refused to comply, arguing the applicant was following an abusive, systematic scheme: subscribe to newsletter → request data access → claim damages.

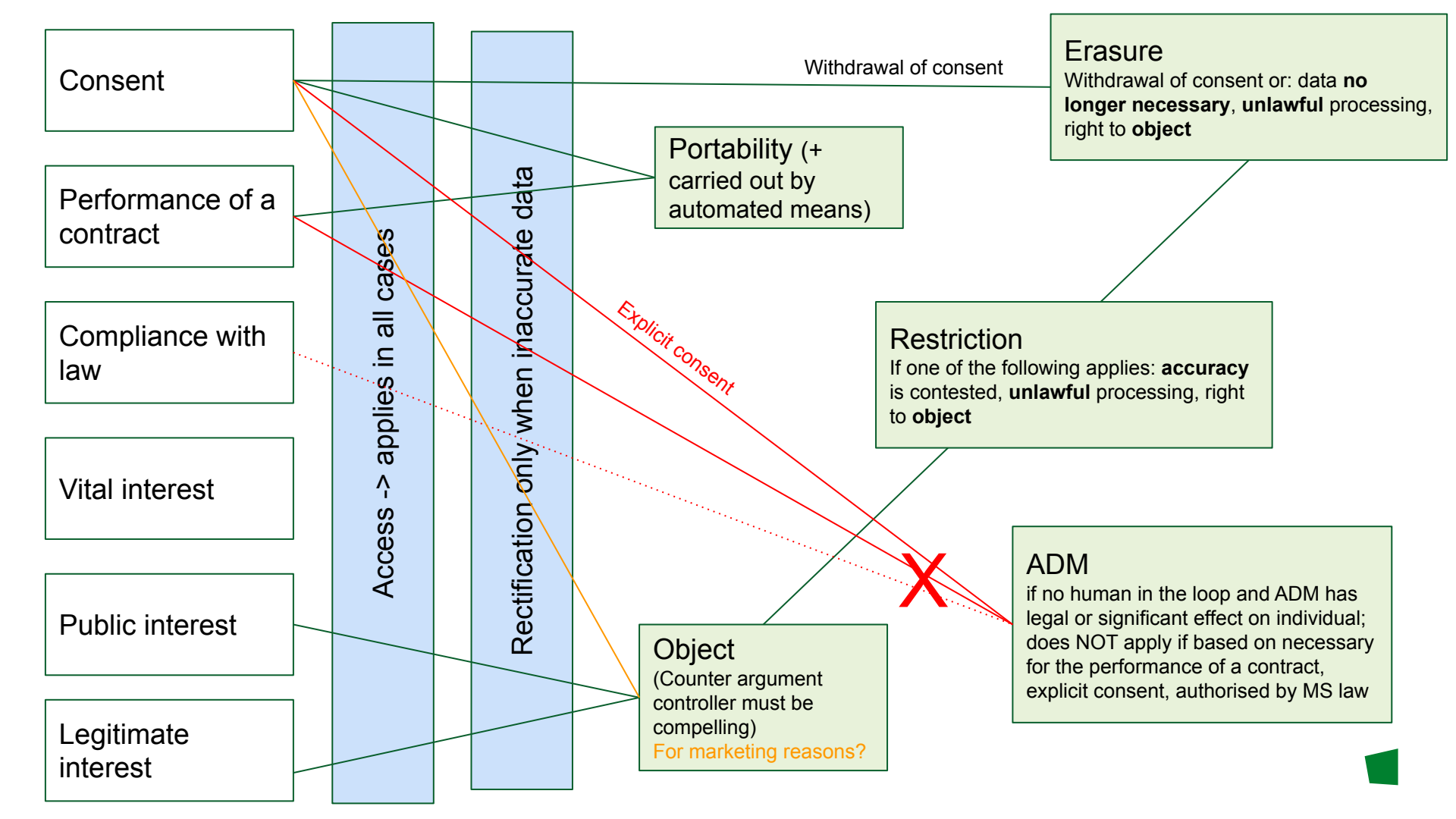
Core Question: Can an initial data access request be deemed "excessive" and therefore an abuse of rights?

CJEU Ruling: Yes, exceptionally. Under Article 12(5) GDPR, "excessive" requests are not limited to repetitive ones; a first request can also qualify. The determination relies on a qualitative assessment:

- Is the request genuinely intended to verify the lawfulness of the data processing?
- Or is it made in bad faith—such as artificially manufacturing grounds for a damages claim or other improper advantages?

The bar is high, and the controller bears the burden of proof. While a pattern of similar requests across various companies can serve as evidence, the decisive factor is not the sheer volume of requests, but whether the right is used for its intended protective purpose or deliberately abused.


Rechtmässigkeit
Treu und Glauben
Zweckbindung
Transparenz
Verhältnis-mässigkeit
Richtigkeit
Daten-sicherheit
«Recht auf Information»
Recht auf Auskunft
Recht auf Berichtigung
Wider-spruchsrecht
Recht auf Daten-portabilität
Recht auf Löschung
Recht auf Einschränk-ung der Verarbeitung
Information
Intervention
Beschaffung
Bearbeitung


Consent
Performance of a contract
Compliance with law
Vital interest
Public interest
Legitimate interest
Access -> applies in all cases
Rectification only when inaccurate data
Withdrawal of consent
Erasure
Withdrawal of consent or: data no longer necessary, unlawful processing, right to object
Portability (+ carried out by automated means)
Explicit consent
Restriction
If one of the following applies: accuracy is contested, unlawful processing, right to object
ADM
if no human in the loop and ADM has legal or significant effect on individual; does NOT apply if based on necessary for the performance of a contract, explicit consent, authorised by MS law
Object
(Counter argument controller must be compelling)
For marketing reasons?

Purpose for processing your data	Legal basis that permits the purpose	Categories of personal data used for the purpose
To provide the Spotify Service (as defined in Section 1 'About this Policy'.)	• Performance of a Contract • Legitimate Interest • Consent	• User Data • Street Address Data • Usage Data • Voice Data • Payment and Purchase Data
To understand, diagnose, troubleshoot, and fix issues with the Spotify Service.	• Performance of a Contract	• User Data • Usage Data
To evaluate and develop new features, technologies, and improvements to the Spotify Service.	• Legitimate Interest	• User Data • Usage Data • Voice Data
For marketing or advertising where the law requires us to collect your consent. For example, when we use cookies to understand your interests or the law requires consent for email marketing.	• Consent	• User Data • Usage Data • Survey and Research Data
For other marketing, promotion and advertising purposes where the law does not require consent. For example, when we use your personal data to tailor advertising to your interests.	• Legitimate Interest	• User Data • Usage Data • Survey and Research Data
To comply with a legal obligation that we are subject to. This might be: • an obligation under the law of the country / region you are in • Swedish law (because of our headquarters in Sweden), or • EU law that applies to us	• Compliance with legal obligations	• User Data • Street Address Data • Usage Data • Voice Data • Payment and Purchase Data • Survey and Research Data

SCHUFA



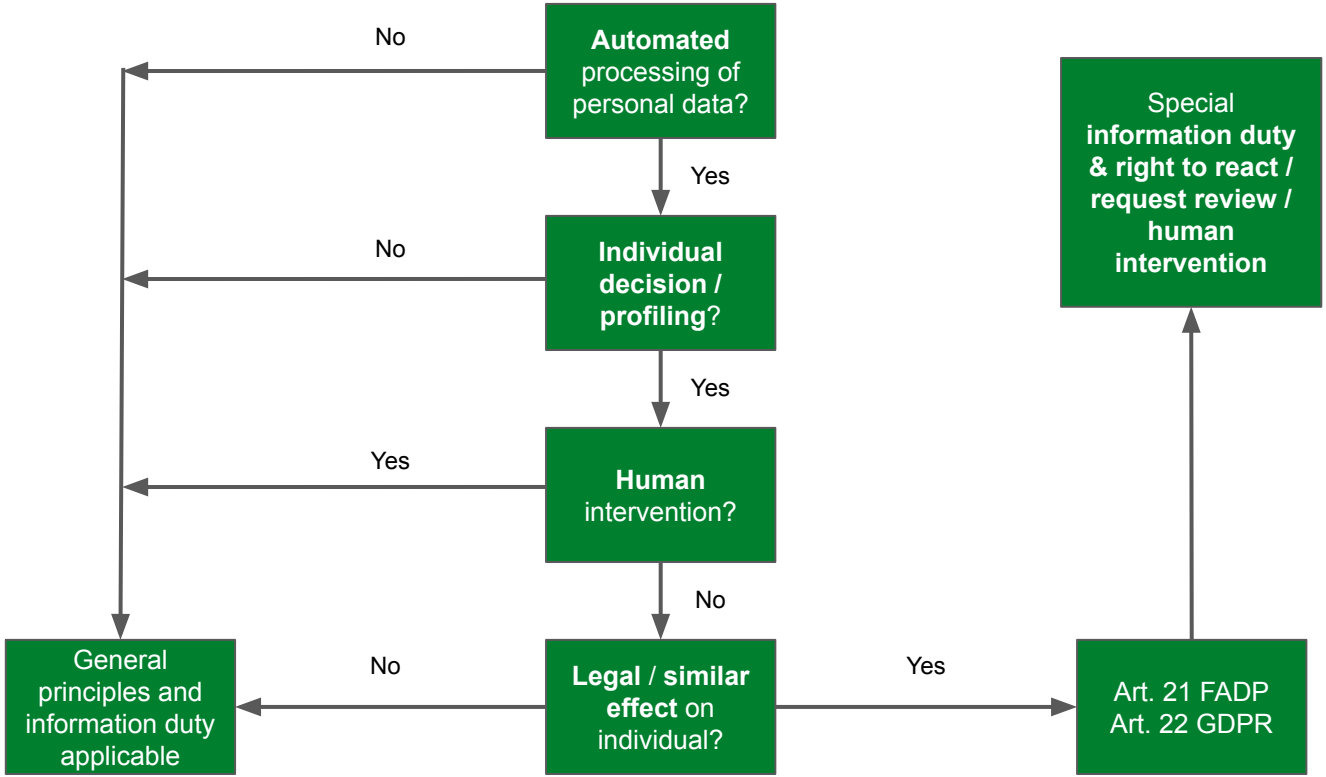
What the SCHUFA score says about your credit risk



> 97,5%	Above **97,5%** - Very low risk
95%	**95 - 97,5%** - Low to negligible risk
90%	**90 - 95%** - Satisfactory to increased risk
80%	**80 - 90%** - Significantly increased to high risk
50%	**50 - 80%** - Very high risk
> 50%	under **50%** - Very critical risk

www.simplegermany.com

Decision tree



Facts: Credit agency SCHUFA automatically generates a credit score assessing a person's likelihood to meet future payment obligations. This score is sent to third parties (e.g., banks), which formally make the contractual decision—though in practice, that decision is heavily driven by the score.

Core Question: Does the automated generation of a credit score itself constitute an automated individual decision under Article 22 GDPR, even if a third party formally makes the final contractual decision?

CJEU Ruling: Yes, if the third party relies decisively on the score. Generating a probability value qualifies as an automated decision when it plays a determining role in the third party's subsequent action. The focus is on the practical impact of the automated outcome, not merely on who signs off on the final step.

Companies cannot bypass Article 22 GDPR simply by claiming the algorithm "only provides a score" rather than making the decision.

> 52 In this regard, it is important to note that, as the Advocate General observed in point 31 of his Opinion, Article 22(1) of the GDPR confers on the data subject the 'right' not to be the subject of a decision solely based on automated processing, including profiling. That provision lays down a prohibition in principle, the infringement of which does not need to be invoked individually by such a person.

Automating erasure of data!







El Parlamento negó la eutanasia en el debate del Código Penal

Mataró, propietat de FERNANDO CANO MOYA. Superfície: 65 m². Càrregues: 1,2 milions de ptes. Tipus de subhasta: 2,05 milions de ptes.

U.R.E. 08/20 (SANT FELIU DE LLOBREGAT) *Tel. 666 56 12*

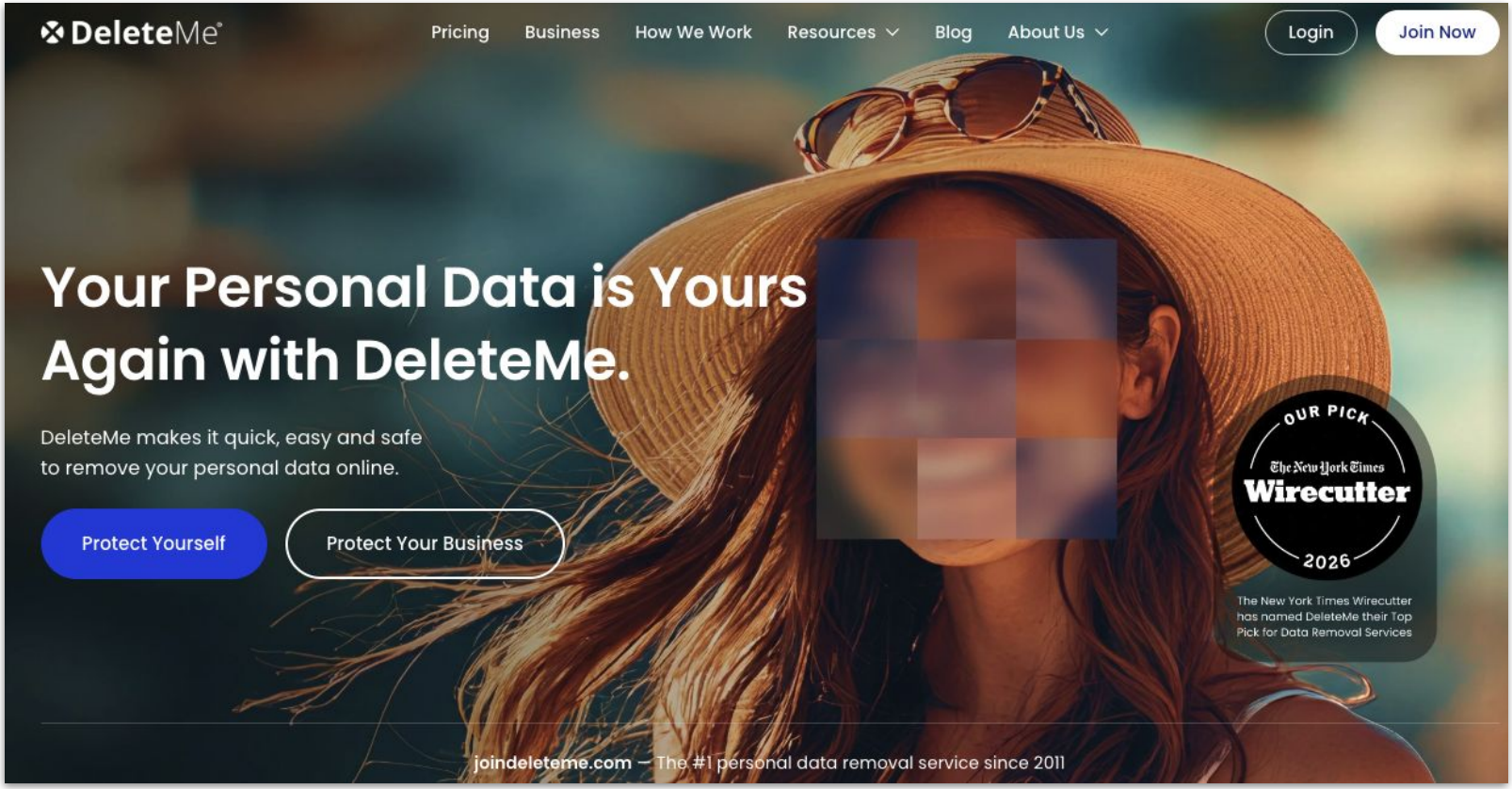
- Meitat indivisa d'un solar al carrer Baix, 55, d'Esparreguera, propietat de DANIEL COCA MAGDALENO. Superfície: 160 m². Sense càrregues. Tipus de subhasta: 3,7 milions de ptes.
- Les dues meitats indivises d'un habitatge al carrer Montseny, 8, propietat de MARIO COSTEJA GONZÁLEZ i ALICIA VARGAS COTS, respectivament. Superfície: 90 m². Càrregues: 8,5 milions de ptes. Tipus de subhasta: 2 milions de ptes. cadascuna de les meitats.
- Meitat indivisa d'un habitatge unifamiliar al carrer Begonia, 8, de la Urb. Mas d'en Gall d'Esparreguera, propietat d'ALFREDO FERNÁNDEZ FERNÁNDEZ. Superfície (total): 317 m². Càrregues: 6,2 milions de ptes. Tipus de subhasta: 2,3 milions de ptes.

U.R.E. 08/23 (VILAFRANCA DEL PENEDÈS) *Tel. 817 19 60*

- Parcel·la amb edificació (xalet), al carrer Pensament, 11, de la Urb. Plana de les Torres de Torrelles de Foix, propietat de JUAN ANTONIO ALBA VILLALÓN. Superfície (total): 1.430 m². Sense càrregues. Tipus de subhasta: 14,2 milions de ptes.

Costeja then contacted Google Spain in February 2010, asking for the erasure of the links to the announcements.

Grounds for removal include cases where the search result(s) "appear to be inadequate, irrelevant or no longer relevant or excessive in the light of the time that had elapsed."


DeleteMe
Pricing
Business
How We Work
Resources
Blog
About Us
Login
Join Now
Your Personal Data is Yours Again with DeleteMe.
DeleteMe makes it quick, easy and safe to remove your personal data online.
Protect Yourself
Protect Your Business
OUR PICK
The New York Times
Wirecutter
2026
The New York Times Wirecutter has named DeleteMe their Top Pick for Data Removal Services
joindeleteme.com – The #1 personal data removal service since 2011

Automated compliance and data protection law are interlinked…. how would you define automated compliance?



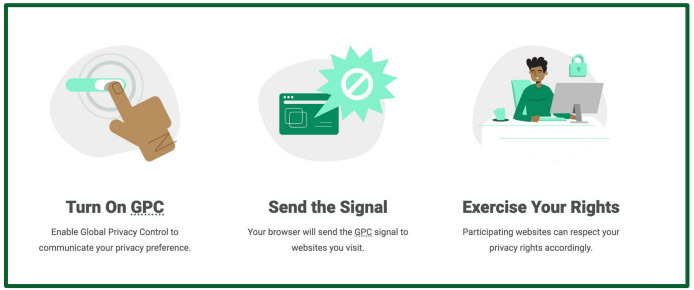
Compliance

- Degree to which the person or entity responsible for something
- Within data protection law
  - Data processing that adequately fulfills the obligations under the GDPR
  - **Principle of accountability**, the data controller has the duty to ensure and be able to demonstrate, through both technical and organizational means, that the processing of personal data is in accordance with the GDPR (Articles 5(2) and 24)

Automated compliance

- Interactions between computer science and law → **Compliance is increasingly supported by digital technologies**
- **By-design approaches** require the implementation of appropriate technical and organizational measures within the design of data processing operations
- In a strict sense automated compliance means that **adherence to rules occurs with little or no human input** and oversight
- **Fully automated compliance is a complex endeavor**, more widely, there is an increasing number of options for compliance automation, which include all tooling that reduces the workload in the compliance process

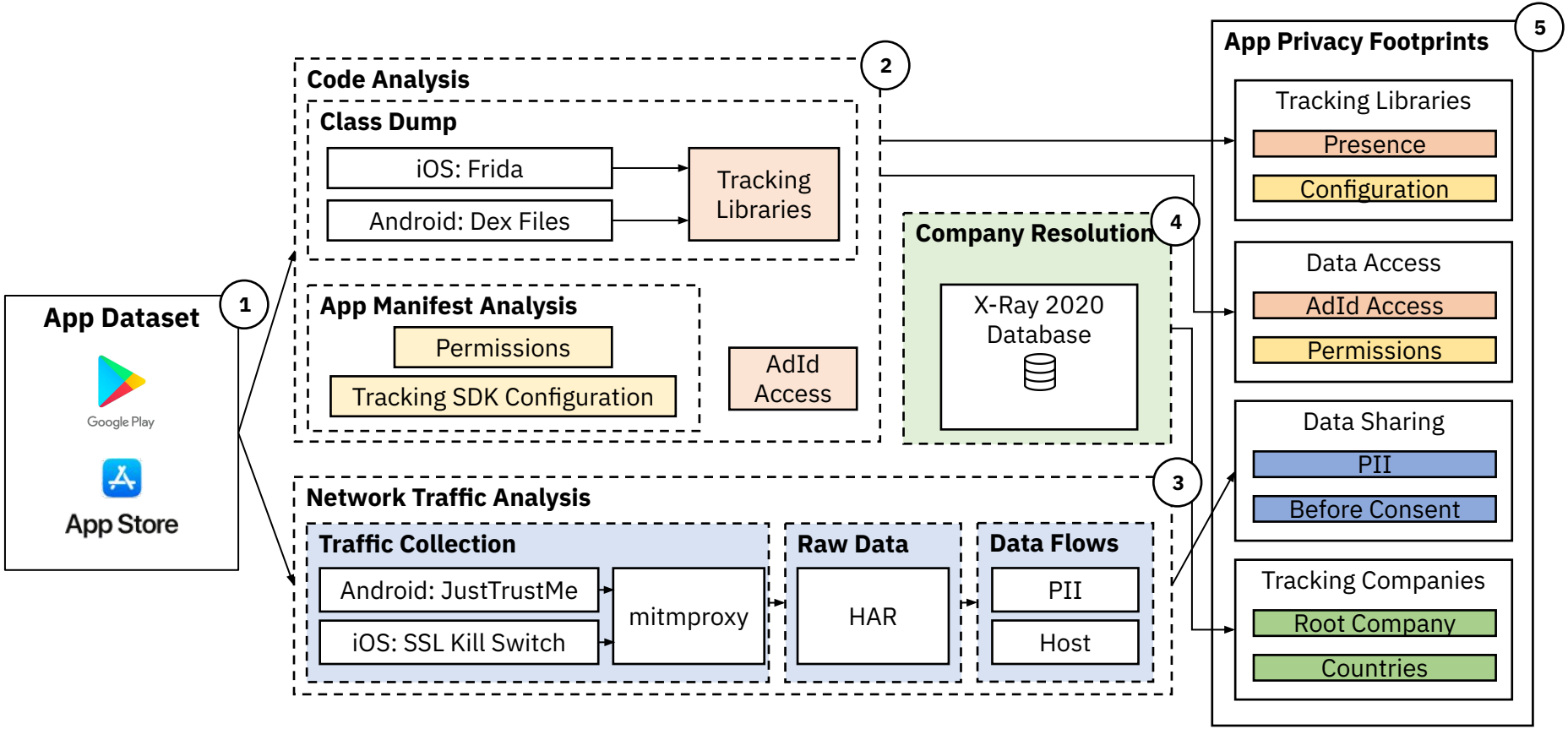
Actors of automated compliance



- **Data subjects**
  - E.g., demanding erasure of data
  - Global Privacy Control (GPC)
- **Data controllers and processors**
  - E.g., Privacy policy generators (e.g., iubenda), data mapping solutions (e.g., OneTrust), and Consent Management Platforms (CMPs) (e.g., Quantcast)
- **Data protection authorities**
  - E.g., European Data Protection Supervisor's (EDPS) open-source Website Evidence Collector to help analyze data protection violations of websites
- **Researchers**
  - E.g., PlatformControl

PlatformControl

Privacy analysis of iOS and Android apps at scale



All code at https://www.platformcontrol.org/

KILL THE COOKIE BANNER.

OPEN LETTER FAQ SUPPORT US TAKE ACTION!

Stop the tracking circus. Kill the cookie banner!

Tired of misleading cookie banners? The EU Commission has finally proposed a solution: set your privacy preferences in the browser once, and never see another banner. Unfortunately, the tracking industry is pushing back – and so far, they've been successful. We need YOUR help to **#KillTheCookieBanner**!

Learn more Take Action!



TrackerControl for Android

- Uses Android's VPN to analyse apps' network traffic *on the device itself*
- Free, open-source, available on GitHub and at https://trackercontrol.org/
- 200 000+ downloads; translated into 20+ languages by the users
- Integrated into DuckDuckGo's app for Android,
  used by millions every day

Video:
https://drive.google.com/file/d/1iDoPng1rQqbihs0LqE32hq9d7qylz5Yr/view?resourcekey

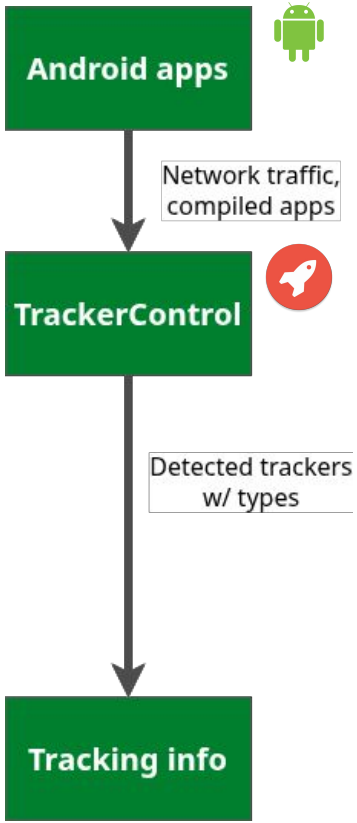


The limitations of TrackerControl

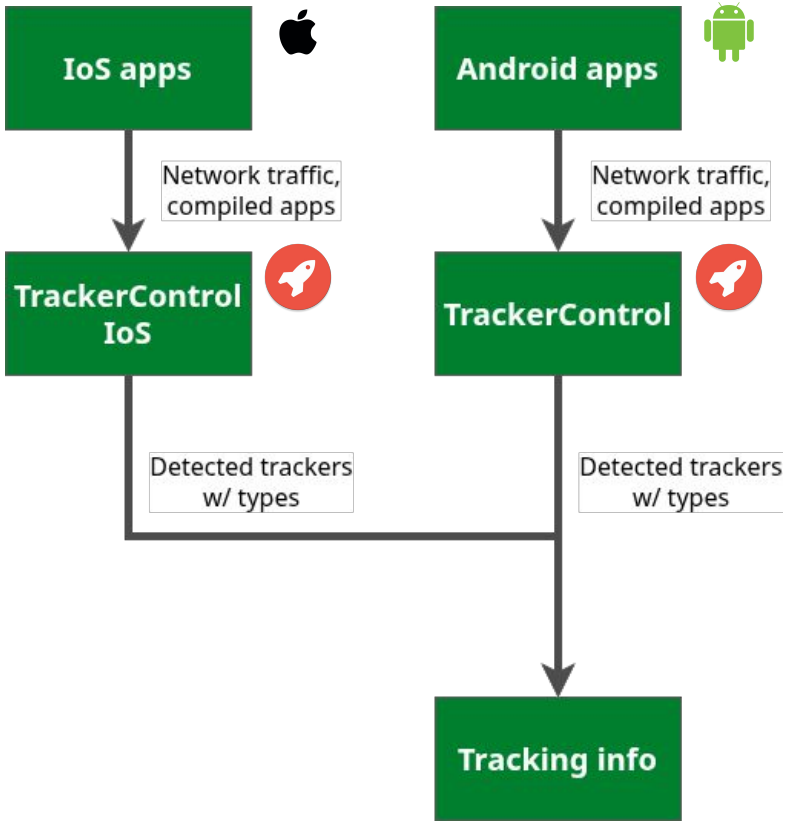
- **TrackerControl is very useful for showing the degree to which third-party data sharing occurs throughout apps. Scope:**
  - **Android apps**
  - **Client-to-server network traffic + static tracker library analysis**
  - **Sharing classification based on provider hostnames**
- **Broader scope possible**
- **Goal: Build a tool which monitors third-party tracking more generally.**



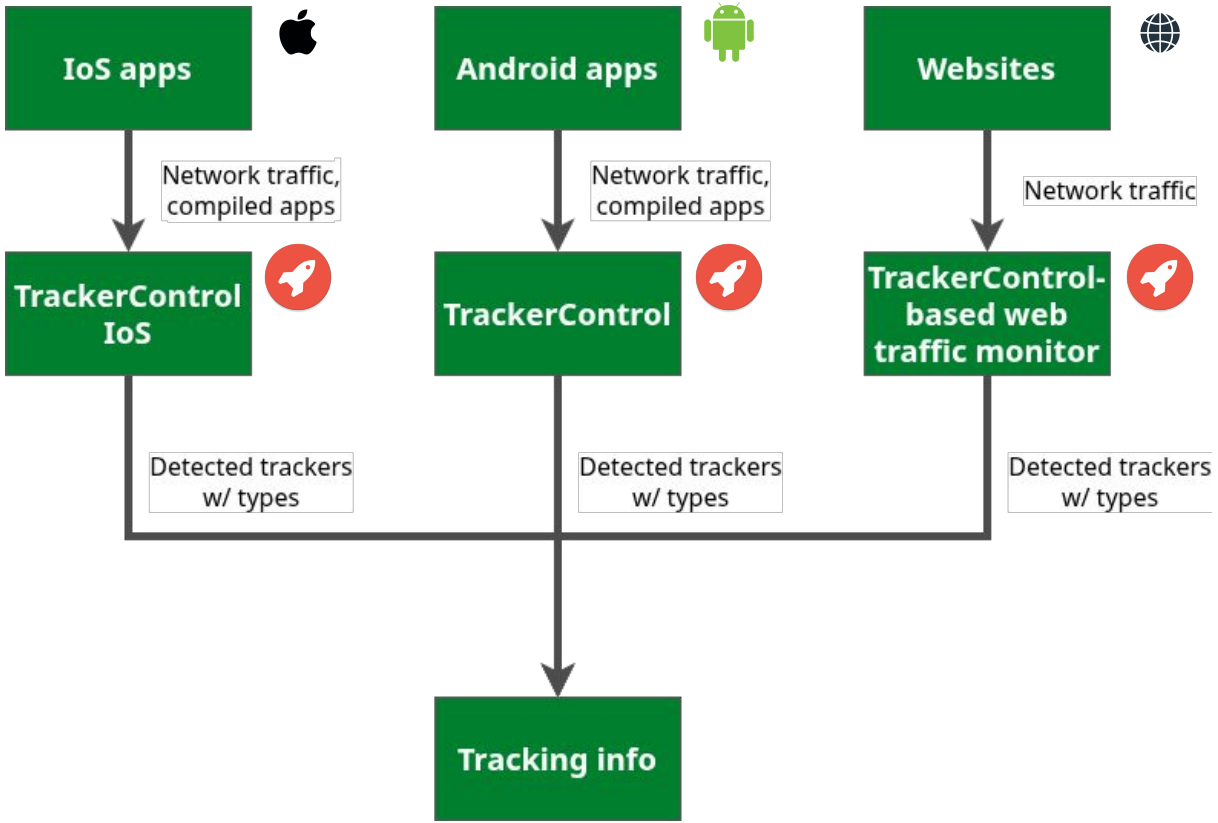
Tracking beyond Android apps



Tracking beyond Android apps

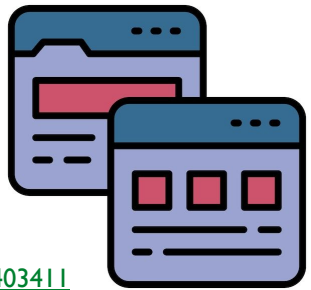


Tracking beyond Android apps



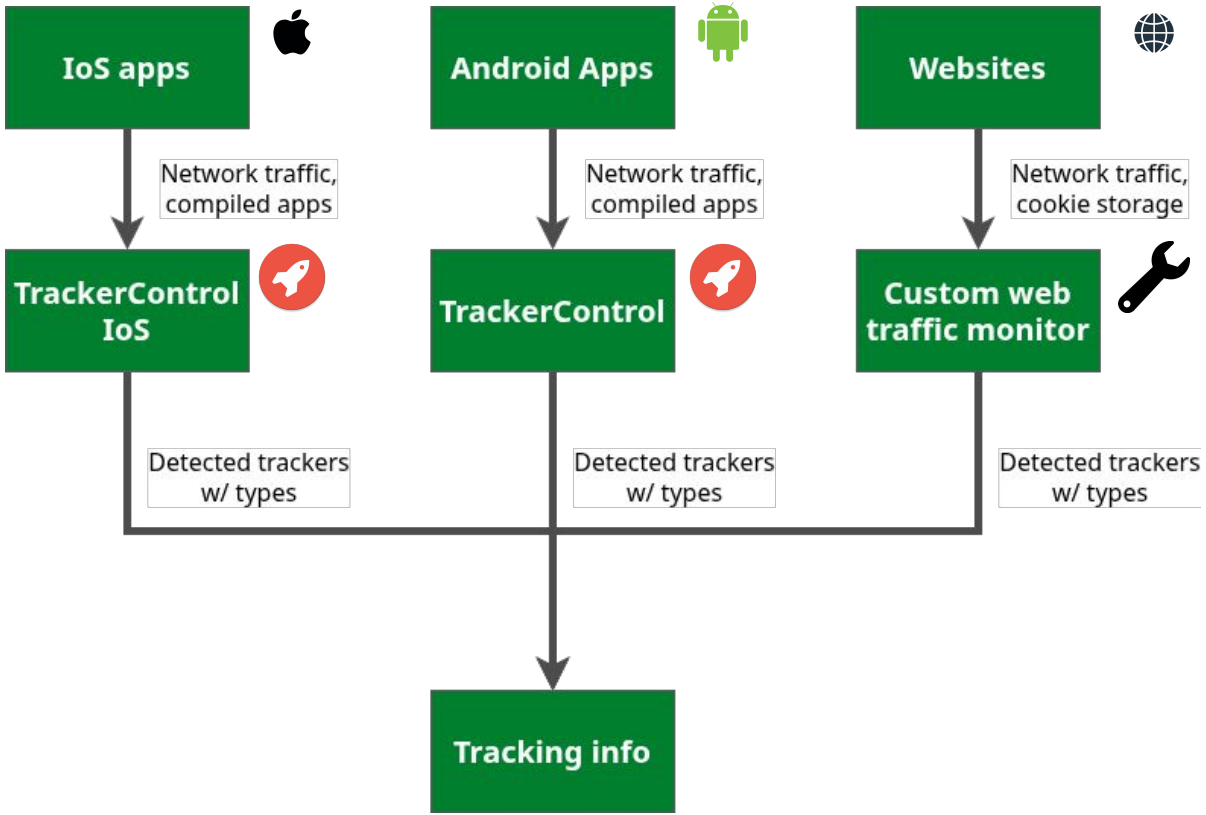
Challenges with analyzing website traffic in a TrackerControl-like manner

- **TrackerControl-like website monitoring does work!**
- **However many false negatives would exist: modern privacy research [1] [2] [3]**
  - **Redirections through an innocuous third party**
  - **Cookie-based approaches**
  - **Browser fingerprinting**
- **-> Custom network analyzer for web to make use of common features**



[1] https://ieeexplore.ieee.org/abstract/document/9403411
[2] https://dl.acm.org/doi/abs/10.1145/3386040
[3] https://dl.acm.org/doi/abs/10.1145/3308558.3313542

Custom web traffic monitor

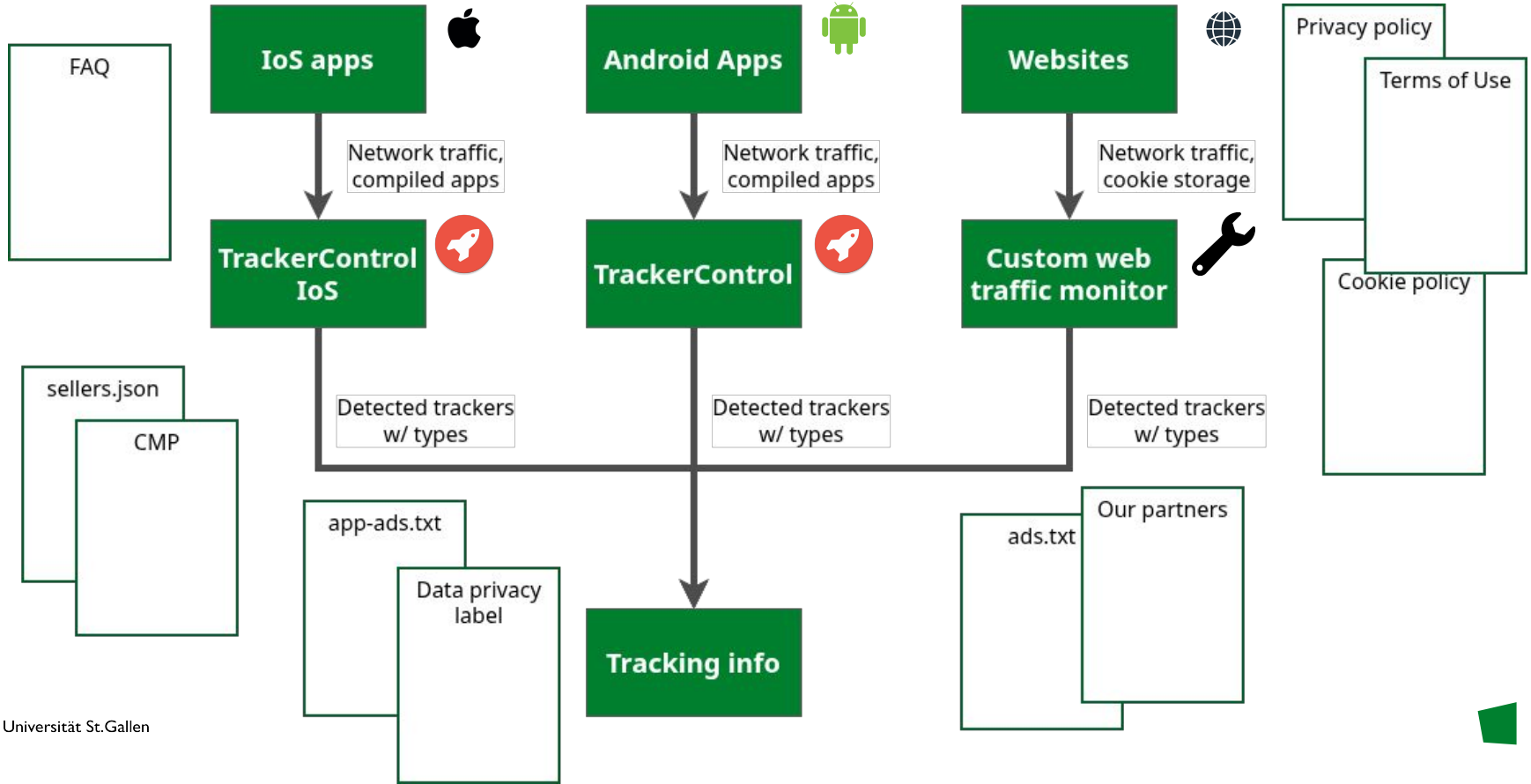


Going beyond monitoring app traffic

- **Our tool fundamentally still relies on observing trackers through monitoring exchanges between client and server, whether app or website.**
- **Unable to establish what happens from server to server**
- **Solution: look at documents which talk about server data handling behavior!**
  - **Privacy policies**
  - **Cookie policies**
  - **Ad-tech documents**
- **Techno-legal landscape**

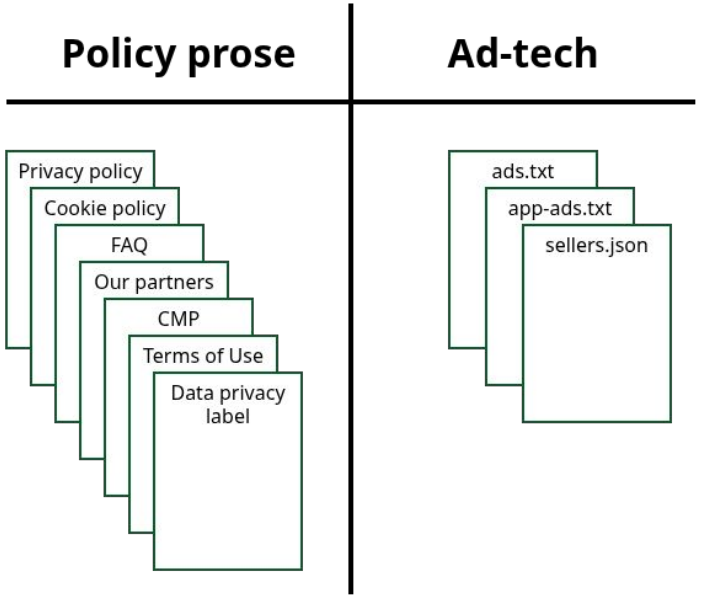


Going beyond monitoring app traffic

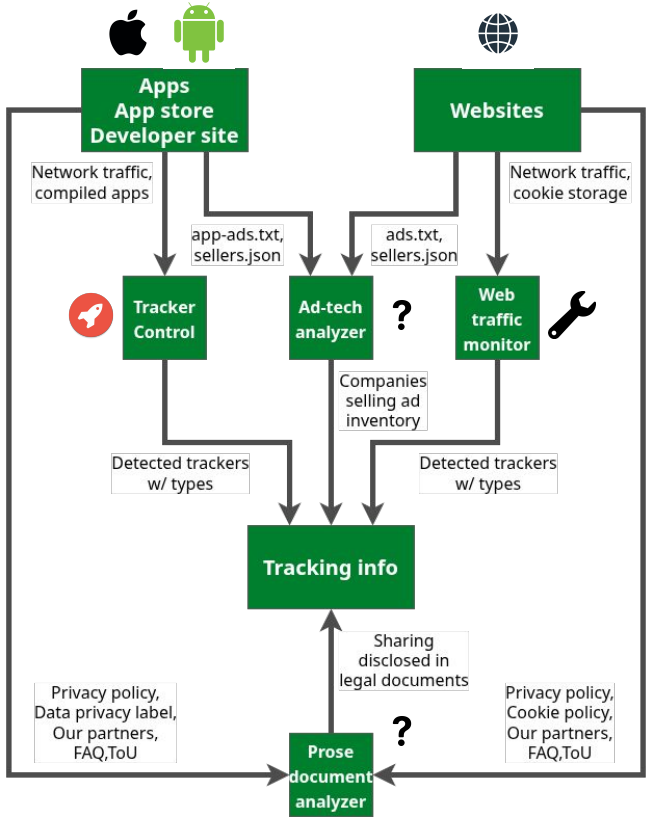


Going beyond monitoring app traffic

- **Challenging to integrate documents into tracking infrastructure**
  - **Documents are prose + legal + heterogeneous**
- **Idea! Two buckets, analyze separately**
- **Policy prose talks about formal data sharing arrangements, ad-tech about ad inventory**



Combining this into the tool

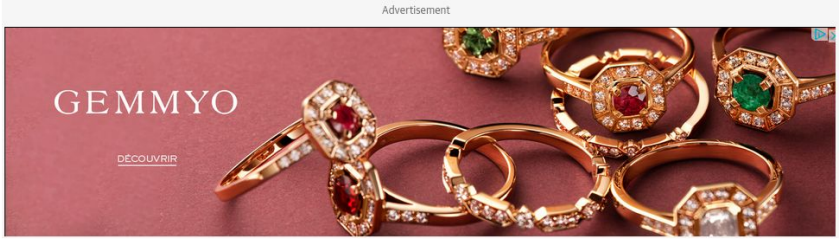


Interlude: What is ad inventory?

- **Places where advertisers are allowed to place their ads, usually in exchange for payment.**
- **ads.txt and app-ads.txt disclose which companies are allowed to sell these places for a particular site.**
- **There also exists an inverse document, sellers.json, which shows from which sites a company is allowed to sell ad inventory.**
- **Ad space is almost always sold in a personalized manner, so looking where it is being sold is a good proxy for checking where information about the user ends up.**



Interlude: What is ad inventory?



- Places where advertisers are allowed to place their ads, usually in exchange for payment.
- ads.txt and app-ads.txt disclose which companies are allowed to sell these places for a particular site.
- There also exists an inverse document, sellers.json, which shows from which sites a company is allowed to sell ad inventory.
- Ad space is almost always sold in a personalized manner, so looking where it is being sold is a good proxy for checking where information about the user ends up.



Creating an ad-tech document analyzer

- **`ads.txt` and `app-ads.txt` are structured files with predictable format**
- **Lists company URL, ID, and whether the selling account is DIRECT (by the provider themselves) or RESELLER (by a third party the provider employs)**
- **sellers.json encodes similar information in reverse.**
- **Straightforward implementation in tracking visualizer.**

```
## ads.txt for Guardian News & Media
## updated: 29/09/2026
###############
OWNERDOMAIN=theguardian.com

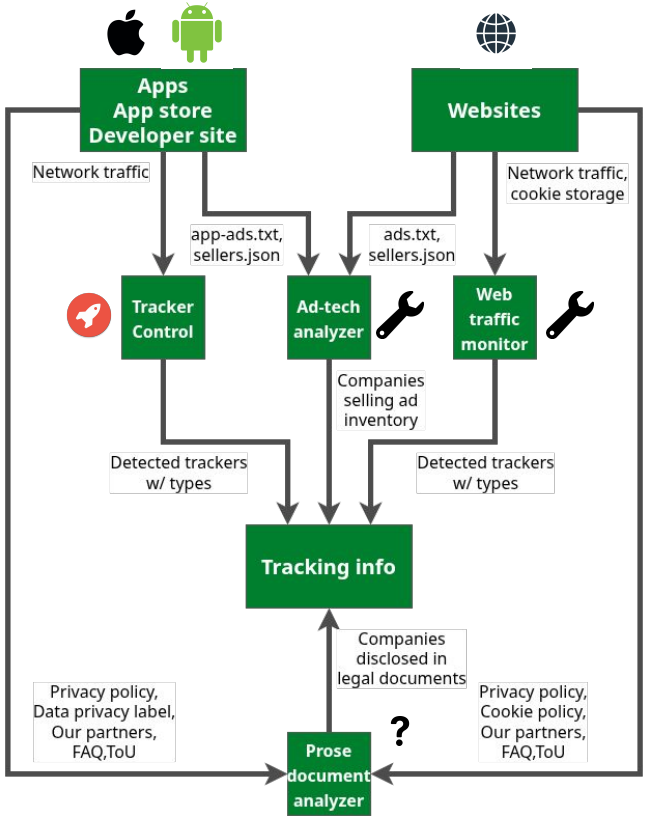
#Google
google.com, pub-2012933198307164, DIRECT #AdX #WW

#Amazon
aps.amazon.com, 3722, DIRECT #WW

#Xandr
appnexus.com, 2888, DIRECT #PBJS #TAM #UK #EU #US #ROW
appnexus.com, 7012, DIRECT #PBJS #TAM #AU

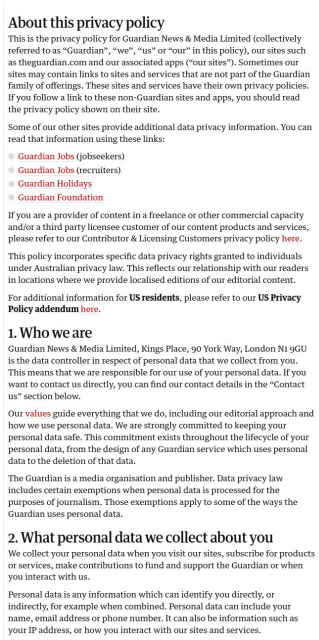
#Index
indexexchange.com, 184842, DIRECT, 50b1c356f2c5c8fc #OB #WW
indexexchange.com, 185406, DIRECT, 50b1c356f2c5c8fc #PBJS #WW
indexexchange.com, 205118, DIRECT, 50b1c356f2c5c8fc #TAM #WW
indexexchange.com, 205545, DIRECT, 50b1c356f2c5c8fc #Ozone #WW
```

Creating an ad-tech document analyzer



Creating a prose document analyzer

- **Challenge: different kinds of data sharing relationships (e.g. "we store data with our server host X" vs "we sell data to advertisers")**
- **Challenge: documents are differently-formatted**
- **(Many) existing NLP approaches exist**
  - **PolicyLint, PoliCheck, …**
- **SOTA is LLM-based**
- **Output data streams**



About this privacy policy

This is the privacy policy for Guardian News & Media Limited (collectively referred to as "Guardian", "we", "us" or "our" in this policy), our sites such as theguardian.com and our associated apps ("our sites"). Sometimes our sites may contain links to sites and services that are not part of the Guardian family of offerings. These sites and services have their own privacy policies. If you follow a link to these non-Guardian sites and apps, you should read the privacy policy shown on their site.

Some of our other sites provide additional data privacy information. You can read that information using these links:

- Guardian Jobs (jobseekers)
- Guardian Jobs (recruiters)
- Guardian Holidays
- Guardian Foundation

If you are a provider of content in a freelance or other commercial capacity and/or a third party licensee customer of our content products and services, please refer to our Contributor & Licensing Customers privacy policy here.

This policy incorporates specific data privacy rights granted to individuals under Australian privacy law. This reflects our relationship with our readers in locations where we provide localised editions of our editorial content.

For additional information for **US residents**, please refer to our **US Privacy Policy addendum** here.

1. Who we are

Guardian News & Media Limited, Kings Place, 90 York Way, London N1 9GU is the data controller in respect of personal data that we collect from you. This means that we are responsible for our use of your personal data. If you want to contact us directly, you can find our contact details in the "Contact us" section below.

Our values guide everything that we do, including our editorial approach and how we use personal data. We are strongly committed to keeping your personal data safe. This commitment exists throughout the lifecycle of your personal data, from the design of any Guardian service which uses personal data to the deletion of that data.

The Guardian is a media organisation and publisher. Data privacy law includes certain exemptions when personal data is processed for the purposes of journalism. Those exemptions apply to some of the ways the Guardian uses personal data.

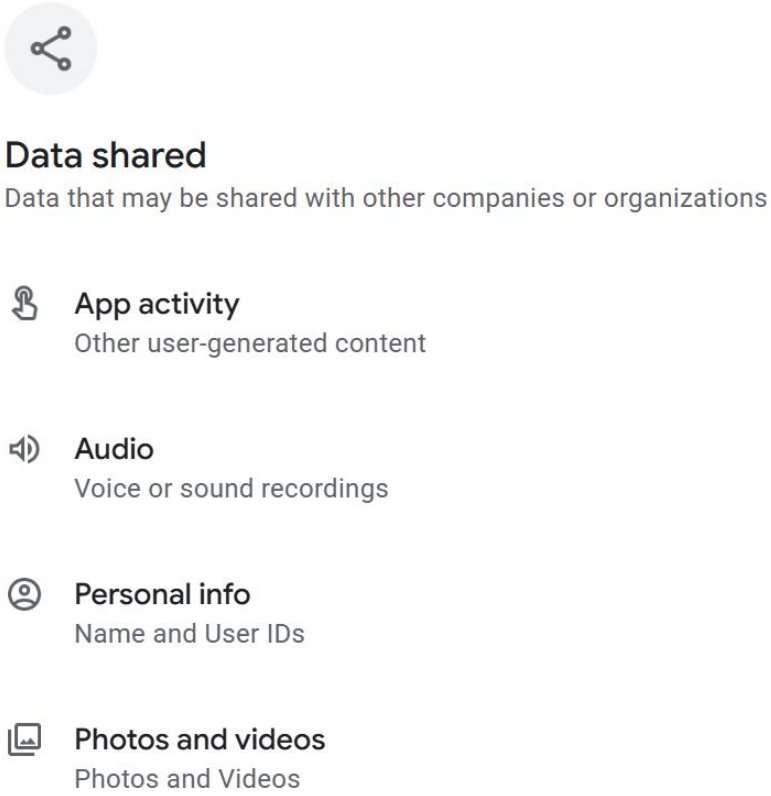
2. What personal data we collect about you

We collect your personal data when you visit our sites, subscribe for products or services, make contributions to fund and support the Guardian or when you interact with us.

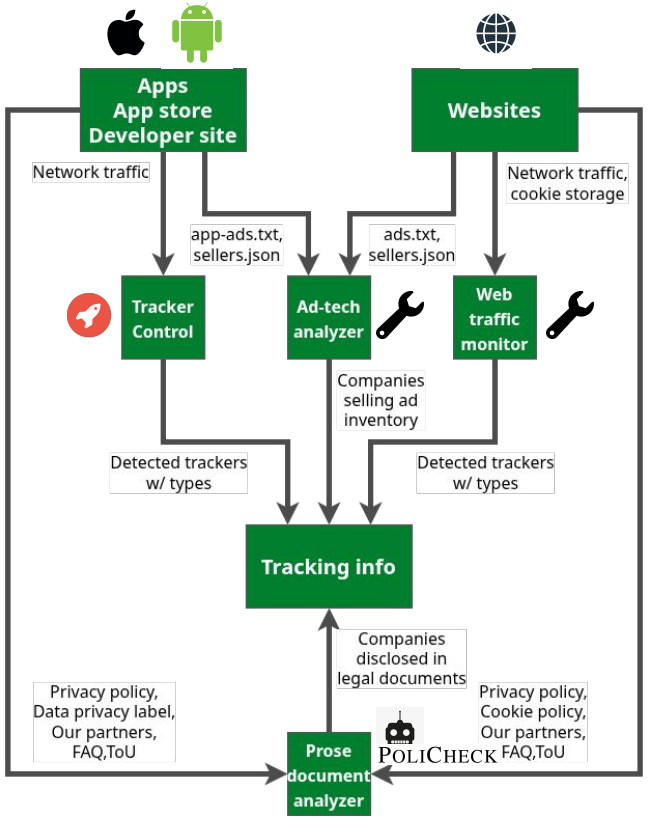
Personal data is any information which can identify you directly, or indirectly, for example when combined. Personal data can include your name, email address or phone number. It can also be information such as your IP address, or how you interact with our sites and services.

App privacy labels

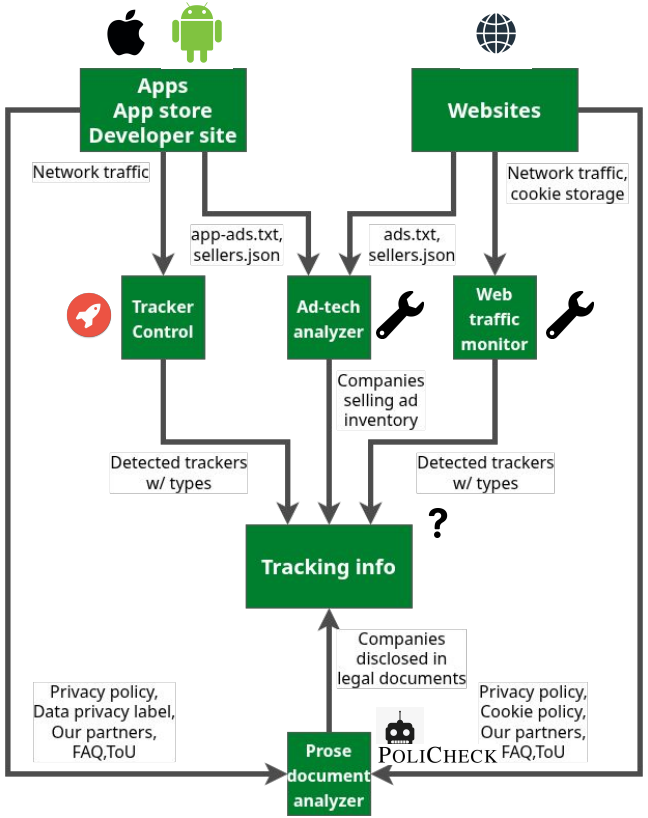
- **Inversely, app privacy labels to provide a high-level overview of how data is shared.**
- **Implemented by both Google Play Store and Apple App Store.**
- **Relaxed guidance for Play Store.**



Creating a prose document analyzer

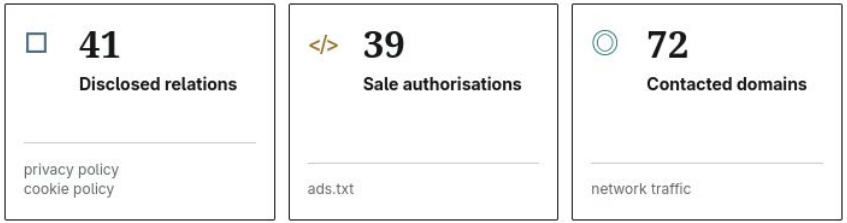


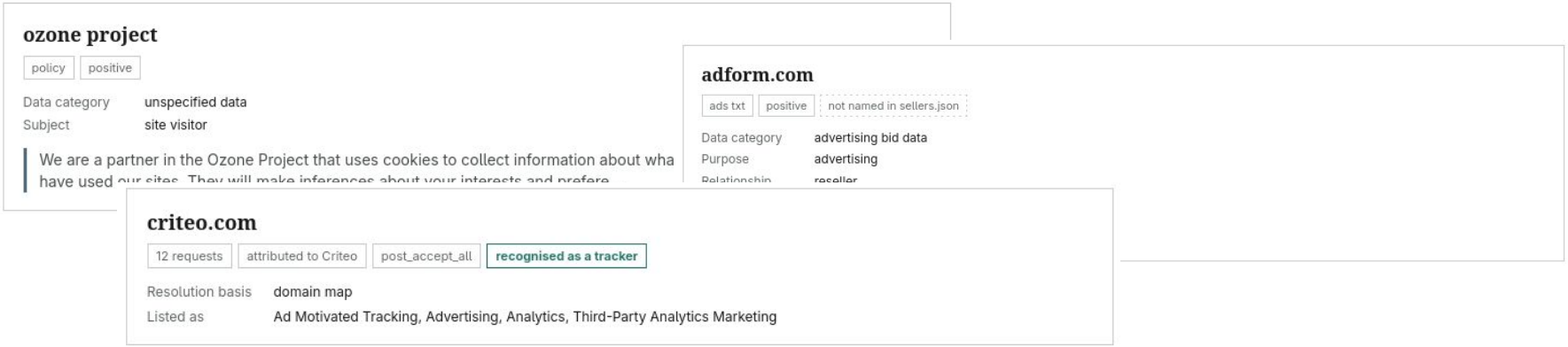
Creating a prose document analyzer

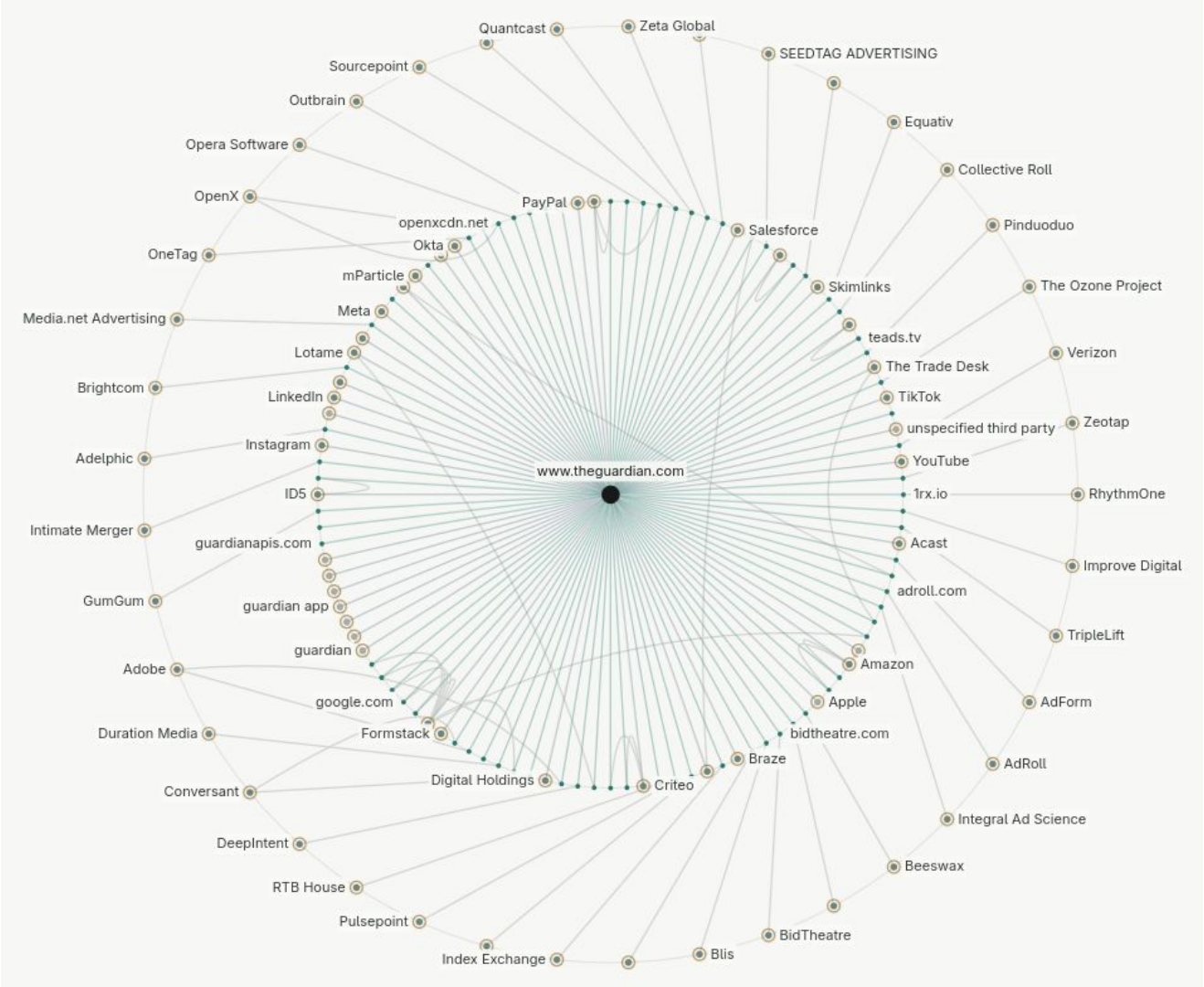


So, with all that, what have we built?

- **Combination gives techno-legal analyzer outputting three kinds of evidence streams of third-party tracking.**

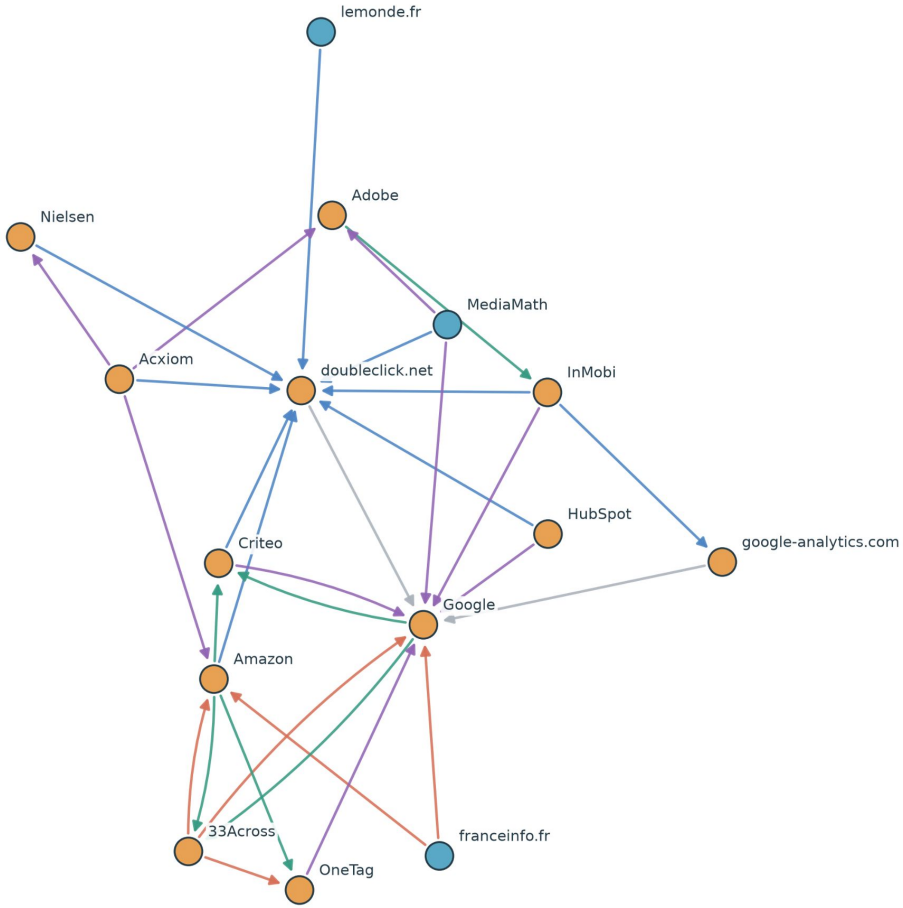






Universität St.Gallen

Evidence Graph



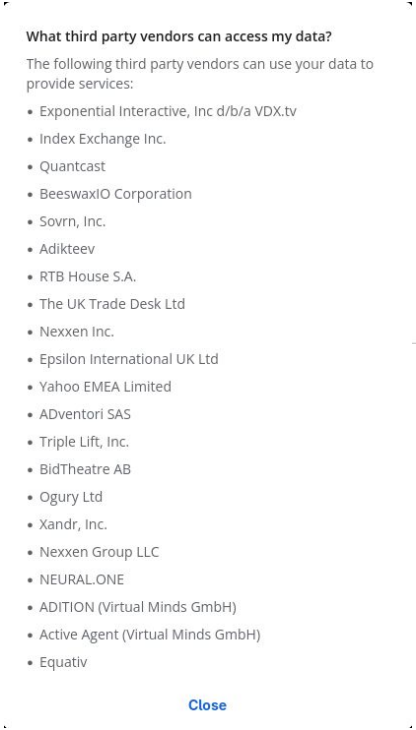
Uncovering contractions

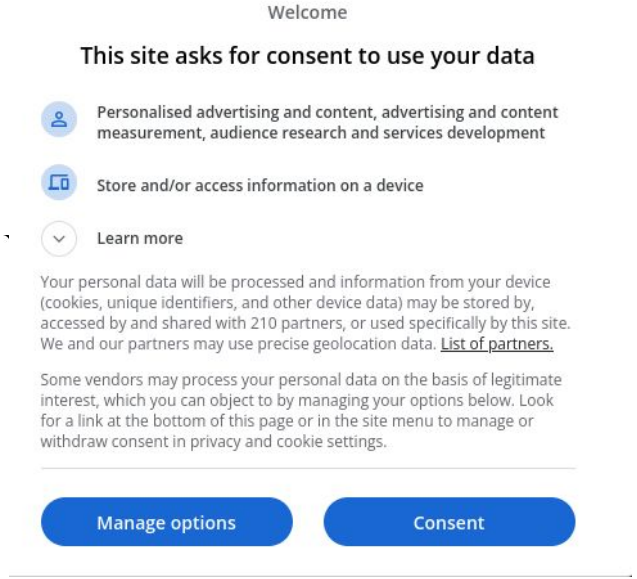
- **Evidence graph might surface various contradictions**
- **Privacy policy might claim that no marketing firms are contacted while network traffic displays various marketing trackers.**
- **Privacy policy may disclaim all advertising while ads.txt claims that there is ad space being sold.**
- **Clarify user's privacy landscape.**



Going beyond the existing vectors

- Cookie banner
  - Dynamically loaded
- Real-time bidding streams
  - User-driven
  - Financial path







What this can be used for



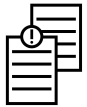
- **Analyzing the global landscape of third party tracking**
- **Help users stay better informed**
- **Help services such as DeleteMe, Incogni**
- **End goal: greater control of data**

incogni



DeleteMe®









Wherever you look, there's no compliance..

sciendo

Konrad Kollnig, Anastasia Shuba, Reuben Binns, Max Van Kleek, and Nigel Shadbolt

Are iPhones Really Better for Privacy? Comparative Study of iOS and Android Apps

Abstract: While many studies have looked at privacy properties of the Android and Google Play app ecosystem, comparatively much less is known about iOS and the Apple App Store, the most widely used ecosystem in the US. At the same time, there is increasing competition around privacy between these smartphone operating system providers. In this paper, we present a study of 24k Android and iOS apps from 2020 along several dimensions relating to user privacy. We find that third-party tracking and the sharing of unique user identifiers was widespread in apps from both ecosystems, even in apps aimed at children. In the children's category, iOS apps used much fewer advertising-related tracking than their Android counterparts, but could more often access children's location (by a factor of 7). Across all studied apps, our study highlights widespread potential violations of US, EU and UK privacy law, including 1) the use of third-party tracking without user consent, 2) the lack of parental consent before sharing PII with third-parties in children's apps, 3) the non-data-minimising configuration of tracking libraries, 4) the sending of personal data to countries without an adequate level of data protection, and 5) the continued absence of transparency around tracking, partly due to design decisions by Apple and Google. Overall, we find that neither platform is clearly better than the other for privacy across the dimensions we studied.

phones [11, 68, 70, 72], which have a variety of always-on sensors and are carried everywhere, and where just two companies dominate both the operating systems and app distribution channels: Apple and Google. Previous research on smartphone privacy has focused on one of these companies – Google and the Android ecosystem [12, 36, 37, 49, 54, 55, 57, 58, 60, 67, 68, 70] – but limited research exists on Apple's iOS and App Store ecosystem [11, 72], which has a market share of nearly two thirds in the US [21, 61]. Knowledge of the app ecosystem is important both so that consumer choice between platforms can be informed on privacy grounds, but moreover for effective regulation [14, 20, 27, 63, 64] and democratic debate regarding these increasingly important pieces of digital infrastructure.

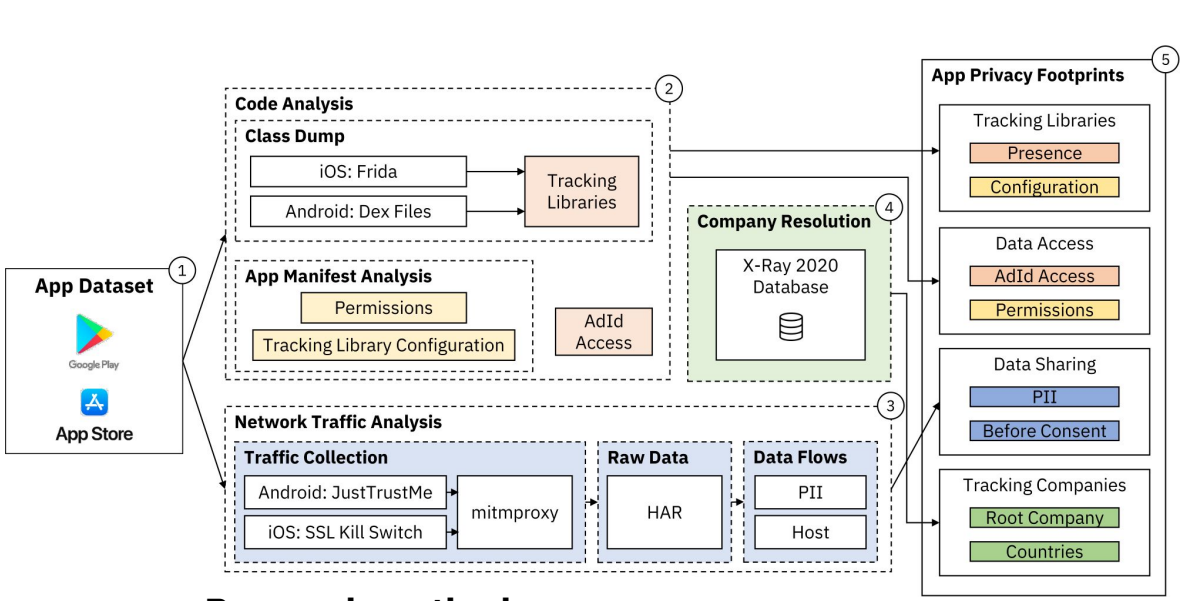
Apple and Google govern their respective app ecosystems, but pursue different strategies with respect to revenue streams, and the freedoms and responsibilities they grant to app publishers and users. In terms of revenue streams, both platforms take a share of up to 30% from all direct revenues created from app sales and in-app purchases, but differ otherwise [38]. Apple profits from the sale of iOS devices and does not license iOS to other device manufacturers. Google's strategy, in contrast, is geared towards the global distribution of Android and Google Play on handsets manufactured by

"widespread potential violations of US, EU and UK privacy law, including

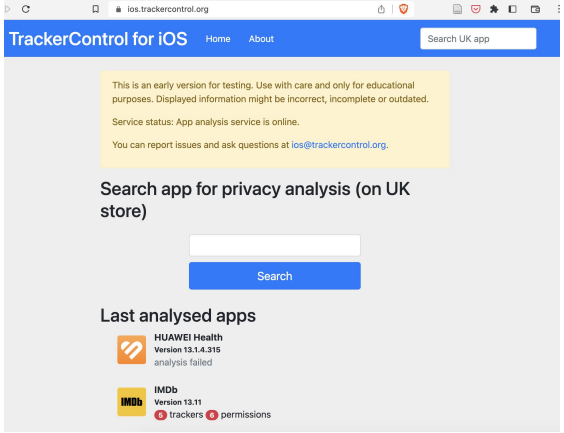
1) the use of third-party tracking **without user consent**,
2) the **lack of parental consent** before sharing PII with third-parties in children's apps,
3) the non-data-minimising configuration of tracking libraries,
4) the sending of personal data to **countries without an adequate level of data protection**, and
5) the continued **absence of transparency** around tracking"

All my methods are public
and rather easy to use

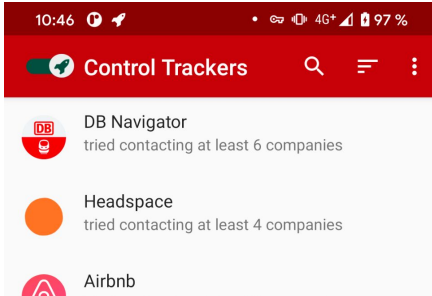
- first public analysis tool for iOS
- over time, at scale, and across Android and iOS
- emphasis on legal questions



Research methods
(at platformcontrol.org)



Apps for iOS
(at ios.trackercontrol.org)



App for Android
(at trackercontrol.org)

Kollnig et al. (2022). Are iPhones Really Better for Privacy? A Comparative Study of iOS and Android Apps. PETS 2022.

Questions?
Feedback?
Suggestions?

